Dokumentasi Teknis — Nusantara Shield v5.4.2

Posko Pertahanan Siber Luring: Peringatan Dini, Isolasi Cepat, dan Rantai Bukti Forensik

Versi	5.4.2 · **Buka Insiden dari temuan log asli** (§3.6) dan **tahan tombol dijaga *server*** (§3.7) · 12 November 2026. Sebelumnya 5.4.1 · tambalan hasil tinjauan independen: impor log tahan berkas beracun dan diurai di luar kunci, body impor baru dibaca bila token sah, pendaftaran Pengamat tertutup di pemasang produksi, auditor menangkap penggulungan mundur (`--minimal-titik`), **Saksi Berjenjang Luring** (§2.7.2) · 11 November 2026. Sebelumnya 5.4.0 (9 November 2026): Drill Kesiapan, impor keluaran Wazuh dan Suricata, situs untuk Dewan Juri. Sebelumnya 5.3.0 (1 November 2026): titik periksa log audit bertanda tangan Ed25519 dengan kunci berevolusi
Status uji	**485 / 485 uji otomatis lulus** · diverifikasi dari paket rilis bersih
AI	**Mesin Deteksi Anomali (*anomaly detection engine*) berjalan lokal**: *Isolation Forest* (scikit-learn), dilatih dan dijalankan di *server* satuan, tanpa Application Programming Interface (API) luar
Arsitektur	*Server* FastAPI (Python) · peramban Vanilla JS + Canvas · siaran langsung Server-Sent Events (SSE) · buku berantai HMAC-SHA256
Mode operasi	**Luring penuh**: tanpa internet, Content Delivery Network (CDN), atau layanan awan saat berjalan
Data	Sintetis: Internet Protocol (IP) blok dokumentasi Request for Comments (RFC) 5737, nama orang dan satuan fiktif

Nusantara Shield adalah perisai pertahanan siber (kategori **Penangkalan, *Defensive Shield***) yang **mendeteksi** ancaman (Mesin Deteksi Aturan, AI lokal, dan korelasi kabar ancaman), **mencegah** aset berisiko diserang (WASPADA dan Perketat), dan **membantu merespons** dengan urutan baku bukti → isolasi → LAPSIT yang berjalan otomatis setelah satu keputusan Operator. Di purwarupa, perintah ke perangkat jaringan masih simulasi.

Status fitur. Tabel ini membedakan dengan tegas apa yang sudah didemonstrasikan dan apa yang masih rencana.

Sudah berjalan di purwarupa v5.4.2	Belum dibangun (peta jalan: Mode Hybrid dan eskalasi)
Operasi luring penuh di satu satuan/rumah sakit (*on-premise*)	**(1) Pengiriman LAPSIT otomatis berjenjang** ke Sandi dan Siber Kodam (Sansidam) dan Kartika CSIRT (Pussiberad)
Dua peran: Pengamat dan Operator	**(2) Akses dan tampilan lintas satuan** untuk pemantauan serentak di Mabes
Isolasi dengan tombol yang ditahan 0,6 detik, dijaga *server*	Mesin Asisten Narasi: LLM lokal Llama 3 8B lewat Ollama untuk draf LAPSIT
Rantai bukti HMAC-SHA256	Umpan indikator resmi (BSSN/MISP) lewat gerbang satu arah
Korelasi CTI dan Mesin Deteksi Anomali (*Isolation Forest*, luring)	Aliran langsung dari sensor (Wazuh, Suricata, Zeek; kini lewat impor berkas keluarannya) dan sakelar terkelola sungguhan
Simulasi OT genset (Modbus, *port* 502)	Peristiwa identitas nyata dari Active Directory (perubahan hak akses, akun baru)
Pembuatan LAPSIT dan ekspor PDF	Pengamanan integrasi nyata: brankas kredensial, hak minimum per *playbook*, *playbook* bertanda tangan
Paket pasang luring bersidik jari SHA-256 (tanpa internet sama sekali)	**Respons bertingkat menurut kritikalitas aset:** aset vital tetap dua kunci; *endpoint* kantor berisiko rendah diisolasi otomatis dengan praotorisasi
Mesin Deteksi Aturan: *login* gagal berulang, *login* tembus, pemindaian *port* (§2.8)	
Linimasa 60 menit (data latihan), pita anomali AI per aset, KPI MTTC dan insiden (§2.8)	

1. Spesifikasi Lingkungan dan Dependensi

1.1 Kebutuhan Perangkat

Komponen	Kebutuhan minimum	Catatan operasional
Sistem operasi	Linux, macOS, atau Windows 10+	Uji otomatis diverifikasi di Linux; Windows memakai `run_tests.bat`
Python	**3.10 atau lebih baru**	Satu-satunya *runtime* yang perlu dipasang
Prosesor	2 inti	Terukur **≈1,5% Central Processing Unit (CPU)** saat siaga dan **≈1,7%** saat serangan untuk 300 layar pemantau serentak (§2.3)
Memori	512 MB bebas	Terukur **≈207 MB** untuk 300 layar, termasuk pustaka AI (scikit-learn dan numpy, ≈130 MB)
Penyimpanan	1 GB	Terukur **≈400 MB** setelah terpasang: pustaka Python ≈380 MB (scikit-learn, NumPy, SciPy), kode dan dokumen ≈12 MB. Paket pasang Ubuntu 95 MB
Peramban	Chrome, Edge, atau Firefox versi terbaru	Tanpa *plugin*; bekerja di jaringan tertutup
Jaringan	Internet sekali saat `pip install`, **atau tidak sama sekali** dengan paket pasang luring (4.4)	Setelah terpasang, seluruh operasi luring
Port	8000/TCP (dapat diubah)	Hanya untuk akses dari jaringan internal satuan

1.2 Dependensi Perangkat Lunak

Pustaka	Versi	Fungsi dalam sistem
fastapi	≥0.115	Loket API, validasi masukan, otorisasi per peran
uvicorn[standard]	≥0.30	*Server* web asinkron (siaran langsung SSE)
reportlab	≥4.0	Ekspor laporan situasi (LAPSIT) ke PDF
scikit-learn	≥1.3	AI lokal: model *Isolation Forest* untuk deteksi anomali (membawa numpy); berjalan luring
pytest	≥8.0	Menjalankan 485 uji otomatis
httpx	≥0.27	Klien uji untuk loket API
hmac, **hashlib**, **secrets**	bawaan Python	Segel HMAC-SHA256 berantai untuk log audit dan Buku Rantai Bukti, sidik jari SHA-256 barang bukti, dan kunci acak. Tidak memakai pustaka kriptografi pihak ketiga

Ringkasnya: *server* memakai **FastAPI**, AI lokal memakai **scikit-learn** (*Isolation Forest*), dan segel bukti memakai **HMAC-SHA256 dari pustaka bawaan Python**. Semuanya sumber terbuka dan dapat diperiksa baris per baris.

1.3 Pengaturan Utama (*Environment Variable*)

Variabel	Fungsi	Bila tidak diisi
`NS_OPERATOR_PASSWORD` · `NS_VIEWER_PASSWORD`	Sandi akun bawaan (min. 12 karakter)	Sandi acak dicetak sekali di terminal
`NS_AUDIT_KEY`	Kunci Hash-based Message Authentication Code (HMAC) buku audit dan buku bukti; mengaktifkan penyimpanan permanen	Buku hanya di memori (mode demo)
`NS_KODE_OPERATOR`	Kode undangan untuk mendaftar sebagai Operator	Pendaftaran Operator mandiri **tertutup**
`NS_DAFTAR_PENGAMAT`	`1` = siapa pun boleh mendaftar sebagai Pengamat	Terbuka di mode pengembangan; **pasang.sh menulis `0`** (v5.4.1)
`NS_HTTPS`	`1` = aktifkan HTTP Strict Transport Security (HSTS) di belakang Hypertext Transfer Protocol Secure (HTTPS)	Nonaktif

Variabel	Fungsi	Bila tidak diisi
`NS_NAMA_POSKO`	Label posko di Berkas Saksi (§2.7.2)	`Posko Nusantara Shield`
`NS_ZONA_WAKTU`	Zona waktu di LAPSIT PDF: `WIB`, `WITA`, atau `WIT`	`WIB`

1.4 Data Latihan Sintetis

Seluruh data di purwarupa **sengaja** sintetis agar aman didemonstrasikan di depan umum:

- **Alamat IP** memakai tiga blok khusus dokumentasi Request for Comments (RFC) 5737: `192.0.2.0/24`, `198.51.100.0/24`, dan `203.0.113.0/24`. Blok ini tidak pernah dipakai di internet sungguhan, sehingga tidak ada alamat milik pihak mana pun yang tercantum.
- **Nama domain contoh** memakai akhiran `.example` dan `.test` yang dicadangkan RFC 2606.
- **Sidik jari berkas berbahaya contoh** memakai berkas uji EICAR, berkas standar yang tidak berbahaya untuk menguji antivirus.
- **Nama orang, satuan, dan aset** fiktif; ciri lalu lintas yang dinilai AI dibangkitkan dari profil sintetis.
- **Peristiwa *login* dan koneksi** untuk latihan deteksi dibangkitkan dari alamat dokumentasi (`203.0.113.77`, `198.51.100.66`, `192.0.2.150`).
- **Linimasa 60 menit** berlabel "data latihan": 60 menit sebelum posko dibuka dibangkitkan dengan benih tetap, tanpa insiden dan tanpa anomali karangan.

---

2. Arsitektur Alur Data

Peran sistem: pendukung keputusan, bukan pengganti keputusan. Nusantara Shield adalah sistem pendukung keputusan (SPK) bagi Operator. Mesin mengamati, mengorelasikan, menilai, dan menyiapkan langkah baku; manusia memutuskan; *server* menjalankan keputusan itu dalam urutan yang dikunci. Sistem ini **sengaja tidak otonom penuh**. Di jaringan vital, respons otomatis penuh membuka tiga risiko: peringatan keliru yang memutus layanan sendiri, respons yang dapat dipancing pihak luar, dan pemutusan tanpa pejabat yang bertanggung jawab (lihat §3.4).

2.1 Alur Data dalam Siklus OODA

```
graph TD
    A["<b>AMATI</b><br/>Aset IT &amp;amp; OT · Radio CTI / OSINT"]
    B["<b>ORIENTASI</b><br/>Korelasi CTI ⇄ inventaris aset + skor anomali AI lokal<br/>→ peluang
serangan per aset"]
    C(["<b>PUTUSKAN</b> · Operator menahan tombol 0,6 detik"])
    subgraph BERTINDAK["BERTINDAK · urutan dikunci server"]
        direction LR
        D1["① Amankan bukti<br/>SHA-256"] ⟶ D2["② Isolasi<br/>jaringan"] ⟶ D3["③
LAPSIT<br/>otomatis"]
    end
    E[("<b>JEJAK HMAC</b><br/>Buku Rantai Bukti · Log audit")]
    A ⟶ B ⟶ C
    C ⟶|"perintah lewat gerbang keamanan"| BERTINDAK
    BERTINDAK ⟶ E

    classDef amati fill:#ecfdf5,stroke:#10b981,stroke-width:2px,color:#064e3b
    classDef orientasi fill:#eef2f7,stroke:#64748b,stroke-width:2px,color:#0f172a
    classDef putuskan fill:#0b1a33,stroke:#0b1a33,stroke-width:2px,color:#ffffff
    classDef bertindak fill:#fef2f2,stroke:#dc2626,stroke-width:2px,color:#7f1d1d
    classDef jejak fill:#e2e8f0,stroke:#0b1a33,stroke-width:2px,color:#0f172a
    class A amati
    class B orientasi
    class C putuskan
    class D1,D2,D3 bertindak
```

```
    class E jejak
    style BERTINDAK fill:#fff7f7,stroke:#dc2626,stroke-width:1.5px,stroke-dasharray:5 4,color:#7f1d1d
```

> **Cara membaca:** data mengalir dari atas ke bawah mengikuti siklus Observe–Orient–Decide–Act (OODA). **Satu-satunya titik keputusan adalah Operator** (kuning). Semua yang di bawahnya dieksekusi mesin dalam urutan terkunci, dan setiap langkah meninggalkan jejak di buku berantai HMAC (ungu).

2.2 Komponen Sistem

Komponen	Berkas	Tanggung jawab
Loket API	`app/main.py`	Menerima perintah, validasi masukan, otorisasi per peran
Gerbang keamanan	`app/keamanan.py`	*Login*, token, peran, batas laju, batas ukuran kiriman 16 KB (impor log ≈2,6 MB, hanya dengan token sah)
Mesin Deteksi Aturan	`app/deteksi.py`	Menghitung peristiwa mentah *login* dan koneksi masuk dengan ambang terbuka; menghasilkan temuan `DET-…` (§2.8)
Mesin Deteksi Anomali (AI lokal)	`app/ai_anomali.py`	Melatih *Isolation Forest* dari profil lalu lintas normal saat *server* menyala; menilai enam ciri lalu lintas tiap aset; menyusun alasan yang bisa dibaca
Dapur situasi	`app/telemetri.py`	Topologi (zona Information Technology (IT) dan zona kendali OT), korelasi Cyber Threat Intelligence (CTI), *playbook* 4 skenario (termasuk Sabotase OT), **kunci urutan bukti → isolasi → pulihkan**
Brankas bukti	`app/bukti.py`	Salinan barang bukti, sidik jari Secure Hash Algorithm 256-bit (SHA-256), berita acara
Buku berantai	`app/audit.py`	HMAC-SHA256 berantai untuk log audit dan Buku Rantai Bukti
Hub siaran	`app/siaran.py`, `app/delta.py`	Satu siaran untuk semua layar; hanya ralat (delta) yang dikirim
Dasbor	`static/`	Peta, radar, kartu Kesiapan Siber, Action Center, alat Operator, manajemen akun

Dasbor menyajikan tiga lapis tampilan pusat komando siber: ***strategic heatmap*** (Peta Global, kotak Postur), ***operational incident board*** (Action Center, Laporan Situasi (LAPSIT)), dan ***tactical endpoint list*** (Topologi Internal, daftar aset).

2.3 Kinerja Terukur

Versi akhir (26 Oktober 2026). Diukur dengan `tools/ukur_beban.py`, yang dapat dijalankan ulang siapa pun: alat ini menyalakan *server*, membuka 300 siaran SSE sungguhan lewat HTTP, lalu mencatat waktu CPU proses *server* selama 60 detik. Mesin: Linux 2 inti, Python 3.13. CPU 100% = satu inti penuh.

Ukuran (300 layar serentak)	Siaga	Serangan (ransomware + DDoS, latihan AI dan deteksi)
CPU *server*, sebelum linimasa dan KPI	1,43%	1,60%
CPU *server*, **versi akhir**	**1,47%**	**1,67%**
Lalu lintas siaran ke 300 layar	0,28 MB/s	0,40 MB/s
Memori proses *server* (termasuk pustaka AI)	≈207 MB	≈207 MB
Siaran yang tetap hidup	300/300	300/300

Riwayat optimasi siaran ralat (uji beban 15–17 Oktober 2026, Uvicorn + Chromium, mesin dan alat ukur berbeda). Angka ini menunjukkan efek optimasi, bukan beban versi akhir, sehingga tidak dibandingkan langsung dengan tabel di atas.

Ukuran (300 layar serentak)	Sebelum optimasi	Sesudah
CPU *server*	10,8%	2,8%
Memori *server* (sebelum AI)	90 MB	71 MB
Lalu lintas saat serangan intensif	8,4 MB/s	**1,7 MB/s** (−80%)
Kerja grafis kanvas yang tidak terlihat	44 ms/detik	**0 ms**

Setelah AI lokal ditambahkan: melatih model ≈0,16 detik sekali saat *server* menyala; menilai 9 aset ≈10 milidetik, hanya saat keadaan lalu lintas berubah (hasil disimpan per keadaan). Rata-rata tambahan kerja *server* ≈0,05 milidetik per detik.

2.4 Mesin Deteksi Anomali (AI Lokal)

Status: sudah beroperasi penuh di purwarupa, luring. Mesin ini mencari lalu lintas yang **tidak wajar** tanpa menunggu kabar CTI dan tanpa daftar *signature* serangan.

Bagian	Isi
Model	*Isolation Forest* (scikit-learn): 100 pohon, benih acak tetap 2026 sehingga hasilnya dapat diulang dan diaudit
Data latih	1.500 contoh lalu lintas **normal** sintetis, dibuat dan dilatih di *server* saat menyala (≈0,16 detik); tidak ada berkas model yang diunduh
Enam ciri per aset	Jumlah koneksi, volume data, ragam *port* tujuan, *login* gagal, operasi tulis (untuk genset: perintah tulis Modbus), porsi koneksi ke luar jaringan
Skor	0 sampai 1. Lalu lintas wajar ≈0,39; pola tidak wajar 0,61–0,70. **Ambang 0,58**.
Ke peluang serangan	$p_{AI} = \min(0{,}95;\ 0{,}5 + (\text{skor} - 0{,}58) \times 4)$, lalu digabung dengan CTI: $\mathbf{p = 1 - (1 - p_{CTI})(1 - p_{AI})}$. **Perketat** memotong p_{AI} sebesar 70%.
Alasan (*explainability*)	Dua ciri yang paling menyimpang ditulis dalam bahasa manusia, misalnya *"perintah tulis Modbus 10× normal, porsi koneksi ke luar jaringan 8× normal"*
Batas wewenang	AI hanya **menaikkan status** (WASPADA) dan mencatat di log. Ia tidak pernah memutus jaringan; keputusan tetap di tangan Operator (*human-in-the-loop*). Aset yang sedang insiden diurus *playbook*, bukan prediksi AI.

***Local inference* dan *air-gapped* adalah dua hal berbeda.** *Local inference* berarti model dihitung di *server* sendiri, bukan lewat API di internet; mesin ini memenuhinya sejak sekarang. *Air-gapped* berarti jaringan satuan sama sekali tidak tersambung ke internet. Karena mesin ini tidak membuka koneksi apa pun (dikunci uji yang memblokir *socket*), ia **siap** dipasang di jaringan *air-gapped*; paket pustakanya cukup dibawa lewat media yang sudah diperiksa.

Peta jalan: Mesin Asisten Narasi. Model bahasa lokal (*Local LLM*) **Llama 3 8B lewat Ollama** untuk menyusun draf LAPSIT **belum ada** di purwarupa. Ia juga dirancang sebagai *local inference*; untuk satuan *air-gapped*, berkas modelnya diunduh sekali lalu dibawa lewat media yang diperiksa. Model berat ini sengaja tidak dimasukkan ke *server* inti agar CPU tetap hemat; rencananya berjalan sebagai layanan terpisah di *server* satuan dan drafnya tetap diperiksa Operator.

> **Batas purwarupa:** ciri lalu lintas masih **sintetis**. Di lapangan, ciri yang sama diambil dari sensor jaringan (misalnya Zeek atau Suricata), lalu model dilatih ulang dari lalu lintas normal satuan itu sendiri.

2.5 Nilai Kesiapan Siber dan Triase Peringatan

Status: sudah berjalan di purwarupa. Dua fitur ini menjawab pertanyaan pimpinan, "seberapa siap kita sekarang?", dan pertanyaan Operator, "alarm ini benar atau tidak?".

Nilai Kesiapan Siber. Setiap layanan (kelompok aset) diberi dua sub-skor 0–100; makin tinggi makin siap. Rumusnya sengaja sederhana dan terbuka di `app/telemetri.py`:

Bagian	Rumus	Arti
Kerawanan	100 – 50 × rata-rata peluang serangan aset – 30 × porsi aset bertemuan konfigurasi – 20 × (cadangan terlambat atau belum diuji)	Seberapa terbuka layanan sebelum diserang
Insiden	100 – 70 (insiden belum ditahan) atau – 40 (sudah ditahan, belum pulih) – 15 per peringatan WASPADA terbuka (maks. 30)	Seberapa genting keadaan saat ini
Nilai layanan	Yang lebih rendah dari kedua sub-skor	Rantai sekuat mata rantai terlemah
Nilai posko	Rata-rata tertimbang jumlah aset; selama ada insiden yang belum ditahan, paling tinggi D	Ringkasan untuk Dansat

Huruf: **A** ≥ 90 · **B** ≥ 75 · **C** ≥ 60 · **D** ≥ 40 · **E** < 40. Pada keadaan awal demo, posko bernilai A (92); tiga layanan bernilai B karena cadangan terlambat, cadangan belum diuji, dan akses RDP yang terbuka. Kabar celah Modbus menurunkan Genset RS Kesdam ke C, dan Perketat menaikkannya kembali ke B.

Triase peringatan. Operator dapat menutup peringatan WASPADA dengan salah satu dari dua status: **Selesai ditangani** (ancaman sudah ditindak) atau **Positif Palsu (*False Positive*)** (alarm ternyata bukan ancaman).

- Alasan tertulis wajib, minimal 15 karakter. Hanya akun Operator yang dapat menutup; akun Pengamat ditolak (403).
- **Tidak ada yang dihapus.** Berita CTI dan penilaian AI tetap tercatat. Penutupan menjadi halaman baru `PERINGATAN_DITUTUP` di Buku Rantai Bukti (HMAC berantai) dan dicerminkan ke log audit.
- Yang berubah hanya ini: sumber-sumber yang ada saat penutupan tidak lagi menaikkan aset tersebut. **Bukti baru**, yaitu berita CTI lain atau episode anomali AI berikutnya, membuka peringatan lagi.
- Aset yang sedang dalam insiden aktif tidak bisa ditutup lewat triase; penanganannya tetap lewat *playbook*.
- Jumlah *False Positive* ditampilkan terpisah dari Selesai ditangani, sebagai bahan *After-Action Review* (AAR) untuk menyetel ambang CTI dan AI.

Loket: `POST /api/peringatan/tutup` dengan `{aset_id, status: "selesai" | "false_positive", alasan}`. Perilakunya dikunci 16 uji di `tests/test_triase_kesiapan.py`.

2.6 Pemetaan ke NIST CSF 2.0

Status: pemetaan mandiri oleh tim, bukan sertifikasi atau audit kepatuhan. *Cybersecurity Framework* (CSF) 2.0 dari NIST (CSWP 29, terbit 26 Februari 2024) membagi program keamanan siber ke enam fungsi dan 22 kategori. Tabel ini hanya memuat kategori yang benar-benar disentuh Nusantara Shield, beserta uji yang membuktikannya.

Kategori CSF 2.0	Penerapan di Nusantara Shield	Status	Uji
Govern · GV.RR Peran dan wewenang	Peran Pengamat dan Operator; dua kunci konfirmasi; akun Operator hanya lewat kode undangan	Berjalan	`test_keamanan`, `test_akun`
Govern · GV.OV Pengawasan	Nilai Kesiapan Siber A–E untuk Dansat; ringkasan triase (*False Positive* dipisah) sebagai bahan AAR	Berjalan	`test_triase_kesiapan`
Identify · ID.AM Aset	Inventaris dan topologi aset IT serta zona kendali OT	Berjalan (data sintetis)	`test_ot`, `test_telemetri`
Identify · ID.RA Penilaian risiko	Korelasi kabar ancaman × aset; peluang serangan per aset; sub-skor Kerawanan	Berjalan	`test_cti_soar`, `test_triase_kesiapan`
Protect · PR.AA Identitas dan akses	Akses ke posko itu sendiri: PBKDF2–SHA256, token kedaluwarsa, batas laju *login* (§2.7)	Berjalan	`test_keamanan`, `test_akun`

Kategori CSF 2.0	Penerapan di Nusantara Shield	Status	Uji
Protect · PR.PS Keamanan platform	Perketat: model pengerasan aset yang diprediksi diserang	Simulasi; pengerasan perangkat nyata masih peta jalan	`test_cti_soar`
Protect · PR.DS Keamanan data	Kepatuhan Pencadangan < 24 jam dan uji pulih	Berjalan sebagai pencatatan	`test_keamanan`
Detect · DE.CM Pemantauan berkelanjutan	Beban jaringan dan linimasa 60 menit, radar, AI lokal yang menilai ciri lalu lintas setiap detik, serta peristiwa *login* dan koneksi masuk yang dibaca Mesin Deteksi Aturan	Berjalan atas data sintetis; sensor nyata dan peristiwa identitas dari Active Directory masih peta jalan	`test_ai`, `test_telemetri`, `test_deteksi`, `test_linimasa`
Detect · DE.AE Analisis kejadian	*Isolation Forest* yang menyebut alasannya; aturan *login* gagal berulang, *login* tembus, dan pemindaian *port* dengan ambang terbuka; korelasi CTI; triase peringatan	Berjalan	`test_ai`, `test_deteksi`, `test_triase_kesiapan`
Respond · RS.MA Manajemen insiden	Action Center, *playbook* 4 skenario, isolasi praotorisasi; KPI Waktu respons (MTTC)	Berjalan	`test_telemetri`, `test_rantai_bukti`, `test_linimasa`
Respond · RS.AN Analisis insiden	Bukti disegel SHA-256 sebelum isolasi; berita acara bernomor	Berjalan (akuisisi disimulasikan)	`test_rantai_bukti`
Respond · RS.MI Mitigasi insiden	Isolasi IT dan jalur OT ≈1,2 detik sejak keputusan Operator (bukti diamankan di awal jeda); isolasi darurat beralasan	Berjalan (pemutusan disimulasikan)	`test_rantai_bukti`, `test_ot`
Respond · RS.CO Pelaporan insiden	LAPSIT PDF; panggilan cepat ke PIC teknis	Berjalan; pengiriman berjenjang otomatis masih peta jalan	`test_keamanan`, `test_komando`
Recover · RC.RP Eksekusi pemulihan	Pemulihan terkunci sampai sidik jari bukti cocok ulang	Berjalan	`test_rantai_bukti`

Kode kategori dan nama resminya mengikuti NIST CSWP 29; label berbahasa Indonesia di atas adalah ringkasan tim. Semua berkas uji ada di folder `tests/`.

Kategori yang **sengaja tidak diklaim**, antara lain GV.SC (rantai pasok; baru sebatas sidik jari paket luring), PR.AT (pelatihan; Mode Edukasi bukan program pelatihan), dan RC.CO (komunikasi pemulihan ke pihak luar).

2.7 Keamanan Posko Itu Sendiri

Status: sudah berjalan, dikunci uji di `tests/test_keamanan.py`, `tests/test_akun.py`, dan `tests/test_triase_kesiapan.py`. Alat yang memegang tombol isolasi adalah sasaran bernilai tinggi: siapa pun yang menguasainya dapat memutus atau membuka jaringan satuan. Karena itu posko dijaga lebih ketat daripada aset yang dijaganya.

Ancaman terhadap posko	Pengamanan yang berjalan	Dikunci uji
Kata sandi ditebak atau dicuri	Minimal 12 karakter; disimpan sebagai PBKDF2–SHA256 200.000 putaran dengan garam acak 16 byte; dibandingkan dalam waktu konstan. Nama akun yang tidak ada tetap dihitung dengan *hash* tiruan, sehingga lamanya jawaban tidak membocorkan akun mana yang ada. *Login* dibatasi 5 kali per menit per alamat. Mode produksi menolak menyala tanpa kata sandi akun bawaan.	`test_sandi_salah_ditolak`, `test_tebak_sandi_dibatasi`
Sesi dicuri atau dipalsukan	Token acak 32 byte; *server* hanya menyimpan *hash* SHA-256–nya; kedaluwarsa (bawaan 8 jam) dan dicabut saat keluar	`test_token_palsu_ditolak`, `test_logout_mencabut_token`
Penyalahgunaan wewenang	Pengamat ditolak (403) untuk setiap tindakan; akun Operator hanya lewat kode undangan (dibandingkan dalam waktu konstan) atau dibuat Operator lain	`test_pengamat_tidak_boleh_mengubah`, `test_hanya_operator_yang_boleh_menutup`
Skrip jahat atau halaman disusupi	CSP hanya mengizinkan skrip dan gaya milik sendiri; `X-Frame-Options: DENY`, `nosniff`, `Referrer-Policy: no-referrer`; tanpa CDN	`test_header_keamanan`
Sandi awal dari pemasang diketahui orang lain	Pemasangan produksi (`pasang.sh`) menyalakan `NS_WAJIB_GANTI_SANDI=1`: akun bawaan hanya boleh mengganti sandi atau keluar sampai sandi awal diganti (min. 12 karakter, berbeda, tanpa nama akun). Penggantian dibatasi laju seperti *login*, mencabut sesi lain akun itu, tercatat `GANTI_SANDI` tanpa sandi, dan hanya hash-nya yang disimpan	`test_akun.py` (bagian c)
Banjir kiriman	Batas laju per kelompok loket; kiriman di atas 16 KB ditolak sebelum mencapai logika aplikasi, termasuk kiriman bertahap (*chunked*); impor log boleh ≈2,6 MB, tetapi body baru dibaca bila token sah	`test_kiriman_terlalu_besar_ditolak`, `test_body_chunked_besar_ditolak_sebelum_router`
Masukan aneh	Semua formulir divalidasi ketat; kolom yang tidak dikenal ditolak	`test_input_simulasi_aneh_ditolak`

Ancaman terhadap posko	Pengamanan yang berjalan	Dikunci uji
Pengintaian loket	Dokumentasi API otomatis dimatikan; `/api/health` tidak membocorkan rincian sistem; situs asing ditolak (CORS); nama *host* asing ditolak	`test_dokumentasi_api_dimatikan`, `test_health_tidak_membocorkan_info`, `test_cors_menolak_situs_asing`
Jejak dihapus	Log audit dan Buku Rantai Bukti berantai HMAC-SHA256; satu catatan diubah, rantai putus dan ketahuan. Auditor dapat memeriksanya **tanpa menyalakan *server*** dengan `tools/verifikasi_audit.py` (pustaka bawaan Python saja, tanpa kode aplikasi); `--cocokkan` mencocokkan sidik jari yang tercetak di LAPSIT sehingga log yang dipotong di ujung juga ketahuan	`test_audit_mendeteksi_manipulasi`, `test_verifikasi_audit.py`
Riwayat ditulis ulang oleh pembobol yang memegang `NS_AUDIT_KEY`	**Titik periksa Ed25519 dengan kunci berevolusi** (sejak v5.4.0): kepala kedua buku ditandatangani kunci periode berjalan, kunci berikutnya disahkan di titik periksa yang sama, lalu kunci lama ditimpa. Auditor memeriksa dengan sidik jari kunci akar saja, tanpa `NS_AUDIT_KEY`	`test_pencuri_kunci_terkini_tidak_bisa_menulis_ulang_masa_lalu`, `test_titik_periksa_lanjutan_diganti_kunci_curian_tertangkap`
Paket dirusak atau dipalsukan di perjalanan	Daftar sidik jari SHA-256 dicocokkan dengan berita acara sebelum pemasangan; paket Ubuntu 24.04 ditandatangani Ed25519 dan setiap berkas payload diperiksa terhadap manifest sebelum diekstrak (§4.4)	`test_paket_luring.py`, `test_paket_ubuntu.py`

Batas yang perlu diketahui.

- Enkripsi lalu lintas (HTTPS) disediakan *proxy* balik di depan *server*; `NS_HTTPS=1` hanya menambahkan HSTS. Pada demo, *server* berjalan di `127.0.0.1` tanpa HTTPS.
- Sesi dan batas laju disimpan di memori satu proses: hilang saat *server* dinyalakan ulang dan belum dibagi antarproses.
- Belum ada verifikasi dua langkah; rencananya lewat SSO instansi (Proposal §5.2).
- Kunci `NS_AUDIT_KEY` disimpan sebagai variabel lingkungan, belum di modul keamanan perangkat keras (*Hardware Security Module*, HSM). Tanpa kunci ini, kedua buku hanya tersimpan di memori.
- HMAC memakai satu kunci untuk membuat sekaligus memeriksa: siapa pun yang memegang `NS_AUDIT_KEY` (termasuk penyerang yang membobol *server*) dapat membuat entri yang lolos pemeriksaan HMAC. Sejak v5.4.0, entri sampai titik periksa terakhir dilindungi tanda tangan Ed25519 yang kuncinya sudah dihapus (lihat §2.7.1). Entri sesudah titik periksa terakhir masih hanya dilindungi HMAC, dan kunci HMAC sendiri belum berevolusi.
- Insiden dari temuan log asli (§3.6) memakai playbook umum per jenis aturan; dampaknya terbatas pada aset yang tercatat di temuan, sehingga aset lain yang ikut tersentuh penyerang tetapi tidak terekam di log tidak ikut tampil.

- Tahan dijaga *server* (§3.7) untuk menegakkan doktrin, bukan untuk menghalangi skrip yang sengaja menunggu: pemegang akun Operator yang menulis skrip sendiri tetap bisa meminta token, menunggu, lalu mengeksekusi. Yang dijamin: tidak ada pemutusan tanpa niat yang disengaja dan tercatat, dari klien mana pun.
- Angka ≈1,2 detik adalah jeda alur purwarupa (`JEDA_RUNBOOK`), bukan hasil ukur pemutusan sungguhan; pengambilan bukti disimulasikan.
- Akun belum bisa dinonaktifkan atau dihapus dari dasbor, dan Operator belum bisa mencabut sesi akun lain.
- Log **dan** berkas titik periksa yang digulung mundur bersama tetap sah secara kriptografi; yang menangkapnya salinan di luar posko: Saksi Berjenjang Luring (§2.7.2, `--saksi`) atau nomor titik periksa dari LAPSIT terakhir (`--minimal-titik N`). Entri sesudah saksi terakhir belum tercakup.
- Belum ada pengukuran tingkat alarm keliru pada lalu lintas lapangan; semua data uji sintetis.
- Hanya paket Ubuntu 24.04 yang ditandatangani digital; zip luring Mac/Windows masih bersandar pada sidik jari di berita acara. Belum ada uji penetrasi oleh pihak independen.
- **Purwarupa belum memegang kredensial perangkat lain**, karena pemutusan masih simulasi. Saat tersambung ke *firewall*, sakelar, atau Active Directory sungguhan, kredensial itu wajib disimpan di brankas kredensial, setiap *playbook* hanya diberi hak minimum yang diperlukannya, *playbook* ditandatangani digital, dan perubahan *playbook* memerlukan persetujuan dua orang.

2.7.1 Titik Periksa Ed25519 dengan Kunci Berevolusi

Status: sudah berjalan (v5.3.0). Analoginya cap notaris di buku ekspedisi: setiap beberapa halaman dibubuhi cap, cap hari ini sekaligus mengesahkan cap yang dipakai besok, lalu cap hari ini dimusnahkan. Pencuri yang masuk besok hanya menemukan cap besok.

Langkah	Yang terjadi	Kode
Kunci akar	Saat pertama kali menyala dengan `NS_AUDIT_KEY`, *server* membuat kunci Ed25519 periode 1 dan mencatat **sidik jari akar** (SHA-256 kunci publik) di log audit (`KUNCI_TITIK_PERIKSA_DIBUAT`) dan di keluaran *server*. Sidik jari ini dicatat di berita acara	`app/titik_periksa.py`
Titik periksa	Setiap `NS_TITIK_PERIKSA_SETIAP` entri baru (bawaan 25) dan setiap ekspor LAPSIT, *server* menandatangani kepala kedua buku: jumlah entri dan SHA-256 kumulatif entri 1..n (h_k = SHA-256(h_{k-1} ‖ JSON kanonik entri k))	`data/titik_periksa.jsonl`
Evolusi kunci	Titik periksa ke-i memuat kunci publik periode i+1. Sesudah tersimpan, berkas status ditimpa sehingga hanya kunci periode berjalan yang tersisa (izin 600)	`data/titik_periksa_kunci.json`
Pemeriksaan auditor	Tanpa rahasia apa pun: sidik jari akar → rantai kunci publik → tanda tangan → kepala buku dihitung ulang dari berkas log. Alat hanya memakai pustaka bawaan Python (Ed25519 rujukan RFC 8032)	`tools/verifikasi_titik_periksa.py`

```
python3 tools/verifikasi_titik_periksa.py --akar <sidik jari akar dari LAPSIT atau berita acara>
# [SAH]   Titik periksa #1 · … · BERKALA · audit_log 4 entri, rantai_bukti 1 entri
# [SAH]   Titik periksa #2 · … · EKSPOR_LAPSIT · audit_log 7 entri, rantai_bukti 1 entri
# [UTUH]  audit_log: 7 entri dilindungi tanda tangan.
```

LAPSIT bagian 6 mencetak nomor titik periksa dan sidik jari akar. `GET /api/audit/verifikasi` ikut mengembalikan ringkasannya.

Batas yang jujur. Entri sesudah titik periksa terakhir belum dilindungi tanda tangan. Kunci lama dihapus dengan menimpa berkas; pada SSD atau sistem berkas berjurnal, sisa data bisa tertinggal di media, sehingga enkripsi disk penuh tetap dianjurkan. Lapisan ini tidak menolong bila *server* sudah dibobol sebelum kunci akar dibuat, atau bila sidik jari akar tidak pernah dicatat di luar *server*. Bila berkas titik periksa dan berkas status tidak cocok, *server* menonaktifkan titik periksa dan **tidak** membuat akar baru secara diam-diam. Kunci HMAC (`NS_AUDIT_KEY`) sendiri

belum berevolusi. Dikunci 16 uji (`tests/test_titik_periksa.py`), termasuk penyerang yang memegang `NS_AUDIT_KEY` dan kunci periode berjalan sekaligus.

2.7.2 Saksi Berjenjang Luring

Status: sudah berjalan (v5.4.1). Titik periksa tidak menolong bila penyerang mengembalikan log **dan** berkas titik periksa ke keadaan lama: rantai yang lebih pendek tetap sah secara kriptografi. Yang bisa menangkapnya hanya salinan yang disimpan di luar posko. Saksi Berjenjang Luring membuat penyimpanan itu tertib, bisa diperiksa, dan berjenjang mengikuti rantai komando, tanpa jaringan:

```
posko ──Berkas Saksi──▶ satuan atasan (Buku Saksi, Tanda Terima)
                        └──Rekap Saksi──▶ jenjang di atasnya ──▶ …
```

Langkah	Yang terjadi	Kode
Ekspor Saksi	Operator menekan **Ekspor Saksi** (tab Audit & LAPSIT). *Server* membuat titik periksa baru (alasan `SAKSI`), mencatat `EKSPOR_SAKSI` di log audit, lalu mengunduhkan seluruh rantai titik periksa sebagai satu berkas JSON. Isinya sudah bertanda tangan rantai kunci dari akar; nama posko (`NS_NAMA_POSKO`) hanya label. Hanya Operator; mode demo menolak dengan 409	`POST /api/saksi`, `app/titik_periksa.py`
Penyerahan	Lewat media fisik, sesuai jadwal dan prosedur satuan (mis. bersama LAPSIT)	—
Penerimaan	Satuan atasan menjalankan `saksi.py terima`: rantai diperiksa dari akar, lalu dibandingkan dengan kiriman sebelumnya dari posko yang sama. Kiriman baru harus memuat seluruh titik periksa lama, sama persis. Lebih pendek → **digulung mundur**; isi lama berbeda → **bercabang** (kunci periode itu pernah bocor). Keduanya ditolak dan tidak dicatat	`tools/saksi.py`
Buku Saksi	Setiap penerimaan menjadi entri bernomor, berantai SHA-256, dan bertanda tangan kunci Ed25519 milik jenjang itu sendiri, termasuk sidik jari berkas yang diterima. Patokan pembanding adalah entri buku terakhir pengirim itu; arsip kiriman hanya dipakai bila sidik jarinya sama dengan yang tercatat, jadi arsip yang hilang atau ditukar menghentikan penerimaan, bukan meloloskan kiriman mundur. Arsip yang lebih baru tetapi belum tercatat (komputer mati di tengah pencatatan) dipakai sebagai patokan bila memuat kiriman yang tercatat. Buku yang disunting atau terpotong juga menghentikan penerimaan	`buku_saksi.jsonl`, `arsip/`
Pengirim baru	Kiriman pertama dicetak `[BARU]` beserta sidik jarinya. Nama yang sudah tercatat dengan sidik jari lain (akar posko berganti) ditolak kecuali Operator jenjang memberi `--harap <sidik jari baru>` setelah mencocokkannya dengan berita acara. Nama dibandingkan tanpa beda huruf besar, tanda baca, dan lebar huruf, lalu dibersihkan dari karakter kendali terminal. Huruf kembar dari aksara lain (mis. "о" Sirilik) tidak ditangkap, jadi sidik jari `[BARU]` tetap patokan utama	`tools/saksi.py`
Tanda Terima	Posko menerima Tanda Terima bertanda tangan dan memeriksanya dengan `saksi.py periksa-tanda-terima --kunci <sidik jari kunci atasan>`	`tools/saksi.py`
Berjenjang	`saksi.py rekap` mengemas Buku Saksi untuk jenjang di atasnya, yang menerimanya dengan perintah `terima` yang sama. Bila jenjang bawah menulis ulang bukunya sendiri (ia memegang kuncinya), jenjang atas menangkapnya dengan aturan yang sama	`tools/saksi.py`
Isi saksi	Selain tanda tangan, jumlah entri setiap buku di dalam rantai tidak boleh mundur dan buku tidak boleh hilang dari kepala titik periksa, dan kunci berorde kecil (yang bisa "ditandatangani" siapa pun) ditolak	`tools/verifikasi_titik_periksa.py`

Langkah	Yang terjadi	Kode
Pemeriksaan di posko	Auditor membawa saksi dari arsip atasan: `verifikasi_titik_periksa.py --akar <…> --saksi <berkas>`. Rantai di posko harus memuat seluruh titik periksa saksi, sama persis	`tools/verifikasi_titik_periksa.py`

```
python3 tools/saksi.py kunci  --dir SAKSI --label "Sansidam Jaya"
python3 tools/saksi.py terima SAKSI-NusantaraShield-titik2-….json --dir SAKSI --harap <sidik jari akar posko>
# [MAJU]  'Posko RS Lapangan': titik periksa #1 → #2 (1 baru); isi lama sama persis.
# [TERCATAT] Buku Saksi entri #2 · 2026-11-11T01:07:41+00:00 · titik periksa #2
python3 tools/saksi.py terima SAKSI-…-titik1-….json --dir SAKSI
# [RUSAK] Riwayat digulung mundur: kiriman sebelumnya dari 'Posko RS Lapangan' memuat titik periksa sampai #2, …
```

Alat satuan atasan hanya memakai pustaka bawaan Python dan tidak membuka jaringan. Pemeriksa Ed25519–nya sama dengan alat auditor; penandatangannya ditulis menurut RFC 8032 dan diuji identik dengan pustaka *cryptography*.

Batas yang jujur. Kiriman pertama dari pengirim baru dipercaya apa adanya; sidik jarinya dicetak `[BARU]` dan wajib dicocokkan dengan berita acara (atau pakai `--harap`). Entri sesudah saksi terakhir hanya terlindung titik periksa biasa, jadi makin sering saksi diserahkan, makin kecil celahnya. Kunci jenjang disimpan tanpa sandi (izin 600) dan penandatangan Python murni tidak tahan serangan kanal samping waktu, sehingga alat ini dijalankan di komputer luring satuan yang dijaga, bukan di mesin bersama. Penyaluran berkas tidak diotomasi; jadwal dan media penyerahan diatur prosedur satuan. Direktori jenjang (kunci, Buku Saksi, arsip) wajib dicadangkan: arsip yang hilang menghentikan penerimaan dari pengirim itu sampai dipulihkan, karena tanpa arsip kiriman mundur tidak bisa dibandingkan. Dikunci 34 uji (`tests/test_saksi.py`).

2.8 Mesin Deteksi Aturan dan Linimasa Posko

Status: sudah berjalan atas peristiwa sintetis, dikunci uji di `tests/test_deteksi.py` (24 uji), `tests/test_ot_mitre_lapsit.py` (23 uji), dan `tests/test_linimasa.py` (6 uji). Berbeda dari AI yang menilai pola, aturan ini **menghitung**: temuan hanya lahir bila jumlah peristiwa mentah melewati ambang dalam jendela waktunya. Tidak ada baris log yang disuntikkan. Ketiga aturan di bawah ditulis di `app/deteksi.py`.

Aturan	Ambang dan jendela	Keparahan	Sumbangan peluang	Teknik MITRE ATT&CK
Login gagal berulang	≥ 8 gagal dari satu alamat ke satu aset dalam 60 detik	Sedang	0,60	T1110 *Brute Force*
Login tembus	*Login* berhasil dari alamat yang sama ≤ 120 detik setelah rentetan gagal	Tinggi	0,85	T1078 *Valid Accounts*, T1110
Pemindaian *port*	≥ 15 kombinasi aset:*port* berbeda dari satu alamat dalam 10 detik	Tinggi	0,35 per aset	T1046 *Network Service Discovery*
Koneksi IT ke zona kendali OT tanpa izin	Alamat sumber tidak ada di daftar jalur OT yang diizinkan (purwarupa: hanya stasiun rekayasa OT 192.0.2.140)	Tinggi	0,50	T0886 *Remote Services* (ICS)
Perintah tulis Modbus di luar jendela pemeliharaan	Fungsi tulis Modbus 5, 6, 15, atau 16 di luar pukul 22.00–02.00; fungsi baca tidak dihitung	Kritis	0,70	T0855 *Unauthorized Command Message* (ICS)
Rantai IT ke OT	Koneksi tanpa izin disusul perintah tulis dari alamat yang sama ke aset yang sama dalam 600 detik	Kritis	0,90	T0886 dan T0855 (ICS)

- Temuan aktif selama **300 detik** sejak peristiwa terakhirnya; rentetan yang berlanjut tidak menggandakan temuan.
- Temuan `DET-…` menjadi sumber ketiga prediksi, digabung dengan CTI dan AI: $p = 1 - \Pi(1 - p_i)$. **Dua kunci tidak berubah:** temuan hanya menaikkan aset ke WASPADA; isolasi tetap keputusan Operator. Perketat memotong sumbangannya (faktor 0,3), dan triase dapat menutupnya beralasan.
- Aset yang sedang ditangani *playbook* insiden tidak dinilai ulang dan diberi label "Aset ditangani lewat playbook insiden".
- **Peringatan terbaru** mengambil labelnya dari data yang tercatat, misalnya "Diisolasi oleh operator · bukti BB-2026-001".
- Latihan: `POST /api/deteksi/latihan` (Operator saja; tercatat di log audit) memutar rangkaian peristiwa sintetis. Latihan **Akses OT tanpa izin** memutar 6 peristiwa ke pengendali genset: stasiun rekayasa resmi tersambung dan membaca register (bukan temuan), lalu stasiun kerja kantor 192.0.2.183 menyeberang ke zona kendali dan mengirim 3 perintah tulis pukul 14.00. Hasilnya tiga temuan dan genset naik ke WASPADA ≈98%; tidak ada insiden, bukti, atau isolasi yang terpicu.
- **Label MITRE ATT&CK®** (`app/mitre.py`, tabel statis luring) tampil di tabel Peringatan terbaru, log peristiwa, dan LAPSIT PDF. Skenario latihan juga dipetakan: *ransomware* T1486, cadangan dimatikan T1490, DDoS T1498, Sabotase OT T0886 dan T0855. AI lokal sengaja tidak diberi label karena ia menilai pola, bukan mengenali teknik tertentu. Pemetaan dilakukan tim sendiri sebagai rujukan, bukan sertifikasi; MITRE ATT&CK® adalah merek dagang The MITRE Corporation.
- **Label batasan.** Setiap peringatan menulis sumber datanya, misalnya "Sumber: peristiwa latihan sintetis · aturan deteksi berjalan nyata" atau "Sumber: skenario latihan · perintah ke perangkat jaringan masih simulasi".

LAPSIT PDF formal. Ekspor LAPSIT (`POST /api/lapsit`, `app/lapsit.py`) disusun seperti laporan insiden formal (gaya SANS/NIST SP 800–61), dengan kop berlogo, nomor laporan, dan "Halaman x dari y" di setiap halaman. Isinya tujuh bagian, semuanya diambil dari keadaan sistem saat dicetak:

1. **Ringkasan eksekutif**: satu atau dua paragraf naratif (apa, kapan, bagaimana ditangani, dan dampaknya) yang dirakit dari data insiden, bukti, laporan, dan MTTC.
2. **Status layanan dan dampak operasional**: dampak terhadap misi tiap layanan dan prosedur kontinjensinya (`DAMPAK_OPERASIONAL` di `app/data_contoh.py`). Ini perkiraan menurut profil layanan contoh, bukan hasil ukur.
3. **Insiden aktif dan tindakan**: kronologi gejala, lalu setiap langkah playbook dengan **waktu eksekusi, T+detik, dan aktor** (akun yang menahan tombol isolasi untuk tindakan SOAR berantai), bukti dan SHA-256–nya, MTTC, dan nomor laporan.
4. **Indikator kompromi (IoC)**: alamat ancaman skenario (berstatus *Diblokir di firewall (simulasi)* hanya bila langkah pemutusnya sudah berjalan), alamat sumber temuan aturan deteksi, dan parameter Modbus (kode fungsi, misalnya 16 *Write Multiple Registers*). Sumber temuan aturan **tidak pernah** ditulis "diblokir", karena aturan tidak memutus apa pun.
5. **Peringatan terbaru** dengan teknik ATT&CK dan label sumber data.
6. **Integritas log audit**: sidik jari HMAC-SHA256 entri terakhir beserta cara auditor mencocokkannya (*Verifikasi rantai* atau `GET /api/audit/verifikasi`). Sidik jari ini menjamin keutuhan log, bukan keutuhan berkas PDF.
7. **Pengesahan** dua tanda tangan.

Waktu ditulis dalam zona `NS_ZONA_WAKTU` (bawaan WIB). Contoh hasilnya ada di `docs/contoh-lapsit/`.

Linimasa 60 menit dan KPI. Linimasa terdiri atas 60 titik × 1 menit ditambah menit berjalan. Saat posko baru dibuka, isinya data latihan berbenih tetap (batang redup); setiap 60 detik, beban posko yang sebenarnya menjadi titik baru, dan menit yang memuat insiden ditandai. Di bawahnya, **pita anomali AI per aset** menyebut nama aset, lama anomali, dan alasan dari model; klik pita menyorot aset di topologi. **Waktu respons (MTTC)** adalah rata-rata dari insiden dimulai sampai langkah penahanan *playbook* selesai, dan **Insiden sejak posko aktif** menghitung insiden yang dimulai. Keduanya dimulai ulang saat demo diatur ulang.

Impor log luring (Fase 3). Operator dapat menyerahkan berkas log **asli** lewat tombol *Impor log…* di bilah Latihan (`POST /api/deteksi/impor`, Operator saja, 6 kali per menit). Modul `app/impor_log.py` hanya menyalin baris yang relevan menjadi peristiwa mentah; **aturan yang menilainya sama persis dengan aturan latihan**.

Format	Baris yang dibaca	Menjadi peristiwa
Log autentikasi OpenSSH (auth.log, secure, journal; stempel syslog atau ISO 8601)	`Failed password/publickey … from IP` dan `Accepted … from IP`	*Login* gagal / berhasil ke aset pilihan (bawaan: Akses admin SSH)
Log firewall UFW/iptables	Baris berisi `SRC=`, `DST=`, `DPT=`	Koneksi masuk; aset dikenali dari pasangan alamat:*port* di inventaris
CSV berkepala `waktu,jenis,sumber,aset,berhasil,ip,port,fungsi,jam`	`jenis` = `login`, `koneksi`, `koneksi_ot`, atau `modbus`	Sesuai jenisnya; `aset` boleh id aset atau alamat IP-nya
Wazuh `alerts.json` (JSON per baris, atau satu larik JSON hasil ekspor)	Peringatan bergrup `authentication_failed` / `invalid_login` dan `authentication_success`, alamat dari `data.srcip`	*Login* gagal / berhasil; aset dari `agent.ip` bila ada di inventaris, selain itu aset pilihan. Peringatan agregat Wazuh (misalnya 5763 *brute force*), `sudo`, dan FIM tidak dihitung: rentetan dinilai aturan kita sendiri dengan ambang terbuka
Suricata `eve.json`	`event_type` `flow`, `alert`, `netflow`; dan `modbus` (`request.function_raw`)	Koneksi (ke *port* 502 aset OT: koneksi ke zona kendali); perintah Modbus. Jam perintah diambil dari stempel waktu sensor, jadi jendela pemeliharaan dinilai menurut jam di lokasi sensor

- **Validasi di batas kepercayaan:** IP harus sah, *port* 1–65535, fungsi Modbus 1–127, jam 0–23, aset harus ada di inventaris. Baris yang tidak sah dilewati dan dihitung (`diabaikan`); berkas tanpa satu pun baris dikenali ditolak 422. Batas ≈2 MB dan 50.000 baris per berkas.
- **Batas ukuran khusus jalur:** hanya `/api/deteksi/impor` yang boleh menerima kiriman sampai ≈2,6 MB, dan body baru dibaca bila tokennya sah (v5.4.1; sebelumnya cukup ada token). Tanpa token sah, kiriman ditolak 401 sebelum body dibaca. Jalur lain tetap 16 KB.
- **Waktu diputar ulang relatif:** peristiwa terakhir di log dianggap terjadi saat ini, jarak antarperistiwa tetap. Jam lokal untuk aturan Modbus diambil dari kolom `jam`, atau dari `waktu` menurut zona waktu *server*.
- **Privasi:** nama akun dalam log tidak disalin ke peristiwa, dan isi log tidak masuk log audit; yang dicatat hanya nama berkas, jumlah baris, dan jumlah temuan.
- **Dua kunci tetap:** temuan dari log asli hanya menaikkan WASPADA. Peringatannya diberi label "Sumber: log impor «nama berkas» dari Operator".
- **Sensor yang sudah dimiliki satuan:** Wazuh dan Suricata dibaca dari berkas keluarannya saja. Nusantara Shield tidak memasang, mengatur, atau menghubungi sensor, dan tidak menjalankan *active response* atau IPS: pemutusan tetap keputusan Operator.
- Contoh berkas sintetis untuk mencoba: `docs/contoh-log/` (auth.log, ufw.log, peristiwa-ot.csv, wazuh-alerts.json, suricata-eve.json).

Batas: telemetri langsung di purwarupa masih sintetis. Log asli dan keluaran Wazuh/Suricata baru masuk lewat impor berkas oleh Operator, belum dialirkan terus-menerus dari sensor (Proposal §5.2). Penerapan nyata

membacanya dari Active Directory, SIEM, atau sensor jaringan satuan (Proposal §5.2).

2.9 Peta Jalan Penguatan dari Studi Banding Arsitektur

Status: satu dari empat sudah dibangun (v5.3.0). Keempat pilar dibandingkan dengan proyek sumber terbuka dan makalah yang relevan (30 Oktober 2026):

Gagasan	Pilar	Masalah yang dijawab	Rujukan studi banding
Evolusi kunci audit dan titik periksa bertanda tangan Ed25519 (**sudah dibangun, v5.3.0**: titik periksa Ed25519 dengan kunci berevolusi; kunci HMAC sendiri belum berevolusi)	Integritas bukti	HMAC memakai satu kunci rahasia untuk membuat sekaligus memeriksa. Bila *server* dibobol, penyerang yang memegang `NS_AUDIT_KEY` bisa menulis ulang riwayat dengan sidik jari yang sah. Kunci yang berevolusi per periode (kunci lama dihapus) membuat catatan masa lalu tidak bisa dipalsukan (*forward security*); titik periksa Ed25519 berkala memungkinkan auditor memeriksa hanya dengan kunci publik	Makalah Nitro (ACM CCS 2025); Trillian dan immudb (log terverifikasi)
Batas waktu *fail-safe* dan aturan dua orang untuk tindakan pemutus	Doktrin Dua Kunci	Setiap tindakan pemutus menjadi Permintaan Otorisasi bernomor yang terikat ke SHA-256 bukti. Kedaluwarsa berarti **tidak dieksekusi** dan tercatat sebagai KEDALUWARSA; untuk aset vital, penyetuju harus akun yang berbeda dari pengusul	StackStorm *Inquiries* (validasi jawaban, TTL); Shuffle (pemicu *User Input* dengan pilihan lanjutkan/batalkan)
Garis dasar Modbus	Konvergensi IT/OT	Peristiwa OT dinormalkan ke format pesan bersama berbasis aktivitas (tanya, jawab, **perintah**), sehingga aturan berlaku lintas protokol (Modbus kini, DNP3 kelak). Pola *polling* dipelajari per pasangan sumber–unit dengan rerata dan simpangan yang diperbarui per peristiwa (algoritma Welford), lalu jeda yang terlalu pendek (skor-Z tinggi) menaikkan WASPADA; ditambah peta rentang register yang sah. Garis dasar baru berlaku setelah **disahkan Operator**	IPAL (RAID 2022); *ics-anomaly-detection* (profil frekuensi *polling*)
Paket intelijen bertanda tangan	Luring	Indikator CTI dan ambang aturan dikirim sebagai berkas terpisah yang diverifikasi kunci rilis yang sama (Ed25519) sebelum diimpor, sehingga intelijen bisa diperbarui lewat media yang diperiksa tanpa internet	Security Onion (pembaruan aturan lewat ISO pada mode *air-gap*)

Semua gagasan di atas ditulis dari nol; yang diambil dari proyek rujukan hanya konsepnya. Titik periksa Ed25519 dibangun lebih dulu (v5.4.0, Dokumentasi Teknis §2.7.1), karena menutup kelemahan nyata pada pilar integritas bukti; tiga gagasan lainnya belum dibangun.

3. SOP Respons Insiden (Workflow F-04)

3.1 Alur Baku



Ringkasan alur baku F-04. Rincian tiap langkah ada di tabel dan diagram urutan berikut.

Kolom pertama memetakan langkah ke siklus *incident response* ***detect*** → ***contain*** → ***eradicate*** → ***recover*** (Purbo dan Lumy, 2025).

Langkah	Tindakan	Siapa	Pengaman yang ditegakkan *server*
1 · Deteksi (*detect*)	Insiden tampil di radar, peta, dan Action Center	Sistem	Korelasi CTI dan skor anomali AI lokal menaikkan aset berisiko ke **WASPADA** lebih awal
2 · Amankan bukti (*chain of custody*)	Salin memori, log, dan trafik (pada purwarupa: berkas simulasi); hitung **SHA-256** tiap berkas; tulis berita acara	Sistem, dipicu Operator	Bukti yang sudah diamankan **tidak bisa dibatalkan** (buku tambah-saja)
3 · Isolasi (*contain*)	Putus jaringan aset terdampak, ≈1,2 detik sejak keputusan Operator (bukti diamankan di awal jeda)	Operator **menahan tombol ⚡ 0,6 detik**	Setiap pemutusan tanpa bukti **ditolak 409**, baik lewat tombol, centang manual, maupun antrean
4 · Lapor	**LAPSIT** bernomor terbit ke pimpinan	Sistem	Terbit **hanya setelah semua** tindakan pemutusan tuntas
5 · Pulihkan (*eradicate*, *recover*)	Hidupkan layanan dari cadangan teruji	Operator	**Terkunci** sampai aset terisolasi, *playbook* dicentang, dan **SHA-256 bukti cocok ulang**
6 · Evaluasi (*After-Action Review*)	Tinjau akar masalah dan perbarui *playbook*	Kasi Siber	Langkah terakhir *playbook*; seluruh jejak tersedia di log audit HMAC

```
sequenceDiagram
    autonumber
    actor Op as Operator
    participant SV as Server
    participant BB as Buku Rantai Bukti
    participant LA as Log audit HMAC
    participant PM as Pimpinan

    Op-->>SV: Tahan ⚡ ISOLASI (0,6 dtk)
    rect rgba(220, 38, 38, 0.10)
        Note over SV,BB: TITIK KRITIS · isolasi dikunci (409)
        SV-->>BB: Amankan bukti · SHA-256
        BB-->>SV: Berita acara BB-2026-001
```

```
        BB-->>LA: Dicerminkan
    end
    Note over SV: Kunci dibuka
    SV⟶»SV: ≈1,2 dtk: isolasi jaringan
    SV⟶»PM: LAPSIT (rujuk BB-2026-001)
    SV⟶»LA: LAPSIT dicatat
    Op⟶»SV: PULIHKAN
    rect rgba(16, 185, 129, 0.10)
        SV⟶»BB: Cocokkan ulang SHA-256
        alt Cocok
            SV-->>Op: Layanan dipulihkan
        else Tidak cocok
            SV-->>Op: 409 · pemulihan dikunci
        end
    end
```

3.2 Isolasi Darurat (*Emergency Override*)

> **Prinsip:** penahanan ancaman yang menyebar cepat **tidak boleh disandera** oleh kegagalan alat forensik. Pengecualian ini **wajib dipertanggungjawabkan**.

- **Kapan tersedia:** hanya bila bukti **belum** dapat diamankan, misalnya agen forensik tidak merespons. Bila bukti sudah aman, isolasi darurat ditolak.
- **Syarat eksekusi:**
  - alasan tertulis, **minimal 15 karakter**;
  - tombol ⚠ **ISOLASI DARURAT** ditahan **1,5 detik**, lebih lama dari jalur standar.
- **Jejak yang tercipta seketika:**
  1. halaman **Buku Rantai Bukti**, berisi alasan, petugas, dan waktu;
  2. entri **log audit HMAC** dengan sidik jari yang sama;
  3. alasan tercantum di **LAPSIT** kepada pimpinan.
- **Setelah ancaman tertahan:** bukti **susulan** wajib diamankan. Pemulihan tetap terkunci sampai sidik jarinya cocok.

Batas purwarupa: lama pengambilan bukti. Angka ≈1,2 detik dihitung dari keputusan Operator sampai jalur pertama terputus, dengan bukti diamankan di awal jeda. Di purwarupa pengambilan bukti **tersimulasi** dan selesai seketika. Di *server* produksi, salinan memori (*memory dump*) 8 GB bisa makan beberapa menit, dan selama itu *ransomware* terus berjalan. Rancangan produksinya (belum dibangun, kecuali lapis 3):

Lapis	Yang diambil	Kapan	Status
1 · Bukti ringkas	Daftar proses, koneksi aktif, sidik jari berkas terdampak	Sebelum diputus, hitungan detik	Rancangan
2 · Salinan memori penuh	*Memory dump* dari *server* yang **sudah terisolasi**	Sesudah diputus	Rancangan
3 · Isolasi Darurat	Putus tanpa menunggu bukti; alasan wajib, bukti susulan	Bukti ringkas macet, enkripsi menyebar ke aset lain, atau layanan nyawa terancam	**Berjalan, diuji**

Memutus jaringan tidak mematikan *server*, jadi isi memori tetap ada untuk lapis 2; yang menghapusnya adalah mematikan atau memulihkan *server*. Isolasi jaringan menghentikan penyebaran dan komunikasi ke server kendali (C2), tetapi **tidak** menghentikan enkripsi lokal di *server* itu.

3.3 Latihan Sinergi IT/OT

Purwarupa memantau aset OT **Pengendali genset** (`192.0.2.120`, **Modbus/TCP *port* 502**) di **zona kendali (OT)** topologi, milik layanan *Genset & Catu Daya RS Kesdam*. Aset IT pasangannya adalah *RS Kesdam · Sistem Informasi*

Manajemen Rumah Sakit (SIMRS). Semua nama aset adalah data contoh. Alur demonstrasi yang dapat diulang:

Langkah	Tindakan Operator	Yang terjadi
1	Panel **Prediksi CTI + AI** → buka *Berita intelijen aktif* → tekan **Latihan OT: siarkan kabar Modbus (genset)**	Kabar **CTI-109** (celah protokol Modbus) masuk Radio CTI
2	Amati topologi dan radar	Genset naik ke **WASPADA**, *risiko* ≈ *66 %* (0,80 keyakinan × 0,75 paparan × 1,1 sektor energi), **sebelum** ada serangan
3	Tekan **Perketat** pada genset	Paparan dipotong 70%; peluang turun di bawah 30%, status kembali normal; tercatat di log audit
4	Panel **Latihan** → target **Genset RS Kesdam** → skenario **Sabotase OT**	Genset **KRITIS** (perintah tulis Modbus asing); penyerang `203.0.113.45:502` tampil di peta
5	Tahan ⚡ **EKSEKUSI ISOLASI** 0,6 detik	Bukti disegel SHA-256 (lalu lintas Modbus, log *workstation* teknisi, konfigurasi pengendali). **≈1,2 detik** kemudian, *webhook* (simulasi) ke sakelar terkelola memutus **jalur kantor → zona kendali**; genset tetap menyala dengan kendali lokal. Akses jarak jauh dicabut, lalu LAPSIT SEV-1 terbit.
6	Centang *Cek fisik*, tekan ♻ **PULIHKAN**	Jalur kendali disambung kembali **hanya** bila sidik jari SHA-256 bukti cocok ulang

Latihan AI (tanpa kabar CTI). Setelah keadaan dikembalikan (tombol **Reset demo**), tekan **Latihan AI: suntik lalu lintas Modbus tak wajar (genset)** di panel Prediksi CTI + AI. Mesin Deteksi Anomali memberi skor **≈0,67** (di atas ambang 0,58), genset naik ke **WASPADA** dengan alasan *"perintah tulis Modbus 10× normal"*, dan log mencatat **"AI lokal ▶ lalu lintas tidak wajar …"**. Aset lain tetap normal. Suntikan berakhir sendiri setelah 5 menit dan log mencatat lalu lintas kembali wajar.

> **Batas purwarupa:** perintah ke sakelar masih **simulasi webhook**, dan sensor protokol industri belum dibangun. Desainnya sudah mengikuti prosedur keselamatan OT (NIST SP 800–82): yang diputus adalah **jalur antara jaringan kantor dan zona kendali**, bukan pengendalinya.

3.4 Pemisahan Wewenang

Peran	Wewenang	Cara memperoleh akun
Pengamat	Melihat seluruh dasbor	Akun bawaan, atau daftar sendiri di halaman masuk
Operator	Melihat, memicu latihan, isolasi IT/OT, pemulihan, menutup peringatan (triase), mengelola akun	Akun bawaan, **kode undangan** (`NS_KODE_OPERATOR`), atau dibuatkan Operator lain

> **Dua kunci konfirmasi sebelum jaringan diputus.** Kunci pertama dipegang mesin: kabar ancaman (CTI) dicocokkan dengan aset satuan dan AI lokal menilai lalu lintasnya, tetapi hasilnya hanya menaikkan status ke WASPADA. Kunci kedua dipegang manusia: hanya akun Operator yang dapat memerintahkan isolasi, dengan menahan tombol 0,6 detik; permintaan dari akun Pengamat ditolak *server*. **Tidak ada satu sinyal pun yang memutus jaringan vital secara otomatis penuh (*autonomous*) tanpa keputusan akhir manusia.** Dikunci uji `test_loket_baru_wajib_login_dan_hanya_operator`: tanpa *login* 401, akun Pengamat 403.

3.5 Drill Kesiapan (*Cyber Drill* untuk Operator)

Status: sudah berjalan di purwarupa (dua skenario). Masalah terbesar yang disebut narasumber Satsiber TNI dan webinar pembekalan lomba sama: SDM siber spesialis langka, dan tim yang tidak pernah berlatih tidak siap saat insiden datang. Perpres 82/2022 memasukkan sektor kesehatan dan pertahanan sebagai Infrastruktur Informasi

Vital (Pasal 4), dan Pasal 15 mewajibkan simulasi tanggap Insiden Siber. Drill Kesiapan adalah simulasi itu, langsung di dasbor yang sama dengan yang dipakai saat insiden sungguhan.

Langkah	Yang terjadi	Dikunci uji
1. Mulai (tab **Drill Kesiapan**, hanya Operator)	Log cerita sintetis (auth.log, 18 baris, alamat RFC 5737) masuk lewat **jalur impor log yang sama** dengan log asli. Mesin Deteksi Aturan menilainya; tidak ada temuan yang disuntikkan. Insiden latihan *Cadangan mati* dimulai di RS Kesdam · SIMRS.	`test_mulai_drill_memutar_log_cerita_lewat_mesin_deteksi_yang_sama`
Skenario	(1) **Cadangan dilepas sebelum serangan** — auth.log, RS Kesdam · SIMRS, insiden *Cadangan mati*. (2) **Perintah asing ke pengendali genset** — keluaran Suricata `eve.json`, Genset RS Kesdam, insiden *Sabotase OT*: HMI resmi membaca register (bukan temuan), stasiun kerja kantor menyeberang lalu menulis register. Cerita OT selalu ditaruh pada pukul 14.00 terakhir agar tetap di luar jendela pemeliharaan 22.00–02.00, kapan pun drill dibuka.	`test_drill_ot_membaca_eve_json_…`, `test_cerita_ot_selalu_di_luar_jendela_pemeliharaan`
2. Kunci jawaban deteksi	Aturan yang seharusnya menangkap cerita ini (login gagal berulang, login tembus) ditampilkan beserta apakah benar-benar muncul. Aturan yang diam ikut dilaporkan, jadi drill sekaligus menguji aturan deteksi (*detection drill*).	`test_aturan_yang_diam_dilaporkan_di_kunci_jawaban`
3. Tangani	Operator merespons dari **Action Center** seperti biasa: isolasi (bukti diamankan lebih dulu), isolasi darurat bila perlu, pemulihan terkunci.	uji rantai bukti yang sudah ada
4. Jawab	Satu pertanyaan per fase (NIST SP 800-61): Deteksi, Analisis, Penahanan, Pemulihan. Kunci jawaban **tidak dikirim ke browser** sebelum pertanyaan dijawab; tiap pertanyaan sekali jawab.	`test_kunci_jawaban_tidak_dikirim_sebelum_dijawab`, `test_jawaban_dinilai_sekali_…`

Langkah	Yang terjadi	Dikunci uji
5. Nilai	Dihitung *server* dari jejak yang tercatat, bukan dari pengakuan Operator. Hasil masuk log audit berantai (`DRILL_MULAI`, `DRILL_JAWAB`, `DRILL_SELESAI`) dan LAPSIT, ditandai **LATIHAN**.	`test_bukti_dulu_dan_cepat_memberi_nilai_penuh`, `test_hasil_drill_tercetak_di_lapsit_sebagai_latihan`

Rumus nilai (terbuka di `app/drill.py`, total 100):

Komponen	Bobot	Sumber angka	Aturan
Ketepatan keputusan	40	Jawaban 4 pertanyaan fase IR	10 per jawaban benar
Bukti sebelum putus	30	Buku Rantai Bukti	Bukti diamankan sebelum jaringan diputus = 30; isolasi darurat lalu bukti susulan = 15; isolasi darurat tanpa bukti atau tidak ada tindakan = 0
Kecepatan penahanan	30	MTTC tercatat sistem	≤180 detik = 30 · ≤420 = 20 · ≤900 = 10 · lebih lama atau belum ditahan = 0

Huruf memakai skala yang sama dengan Kesiapan Siber (A ≥ 90 … E < 40). Ambang kecepatan adalah **target latihan purwarupa, bukan standar resmi**; satuan dapat menyesuaikannya di `AMBANG_KECEPATAN`. Uji mutasi: membocorkan kunci jawaban, mengizinkan jawab ulang, memberi nilai penuh pada isolasi darurat, memalsukan hasil deteksi, mengubah ambang, membuka loket untuk Pengamat, membiarkan drill hidup setelah reset, atau membaca jejak sebelum antrean SOAR diproses, masing-masing membuat uji gagal.

Loket: `GET /api/drill` (semua peran; katalog, drill aktif, riwayat), `POST /api/drill/mulai {kode}`, `POST /api/drill/jawab {no, pilihan}`, `POST /api/drill/selesai` (Operator). 36 uji di `tests/test_drill.py`.

> **Batas yang jujur:** baru dua skenario. Skenario perubahan halaman situs satuan (kasus *deface* mil.id) belum dibangun karena butuh jenis insiden dan aturan deteksi baru. *Tabletop exercise* untuk pimpinan (Dansat, Kepala RS) dengan *inject* bertahap belum dibangun dan masuk peta jalan; doktrin yang sama akan menjadi rubriknya. Drill mengukur keputusan dan kecepatan di purwarupa ini, bukan kemampuan forensik Operator. Riwayat nilai disimpan di memori *server* sampai aplikasi dimulai ulang; jejak permanennya ada di log audit.

3.6 Insiden dari Temuan Log Asli (v5.4.2)

Sebelum v5.4.2, temuan dari log asli hanya menaikkan WASPADA; insiden, bukti, dan isolasi hanya ada di jalur latihan. Kini Operator bisa membuka insiden **langsung dari temuan itu**, tanpa menyalin data apa pun:

1. Operator mengimpor log (auth.log, UFW, CSV, Wazuh `alerts.json`, Suricata `eve.json`). Seperti sebelumnya, impor saja **tidak** membuka insiden.
2. Baris temuan di tabel Peringatan menampilkan tombol **Buka Insiden** bila temuan berasal dari impor, masih aktif, belum ditutup lewat triase, asetnya punya layanan pemilik di inventaris, dan layanan itu belum dalam insiden.
3. *Server* mengusulkan layanan (pemilik aset) dan playbook dari jenis aturan. Aturan IT (*login* gagal berulang, *login* tembus, pemindaian port) memakai playbook **Intrusi dari log asli**; aturan OT memakai playbook **Sabotase OT** (putus jalur IT–OT, genset tetap menyala). Operator membaca usulan itu di dialog lalu memutuskan.
4. Insiden tidak memuat data rekaan: aset terdampak = aset di temuan, kronologi = temuan itu sendiri, label ATT&CK = aturan temuan. Lapisan AI tidak memberi pola lalu lintas latihan ke aset itu, dan peta global tidak menggambar asal serangan.

5. Doktrin sesudahnya sama persis: **AMANKAN BUKTI** lebih dulu, lalu **Eksekusi Isolasi** yang ditahan, laporan setelah semua pemutus selesai, pemulihan lewat pintu terpisah.
6. Berita acara bukti mencatat **SHA-256 asli** berkas log yang diimpor (dihitung saat impor, sama dengan hasil `sha256sum` berkas aslinya), terpisah dari barang bukti lain yang masih simulasi. LAPSIT menyebut asal insiden, nomor temuan, nama berkas, dan sidik jarinya. Log audit mencatat `INSIDEN_DARI_TEMUAN`.

Loket: `POST /api/insiden/dari-temuan {"temuan_id"}` (hanya Operator). Skenario `intrusi_log` tidak bisa dipicu lewat tombol simulasi. Dikunci `tests/test_insiden_temuan.py`.

3.7 Tahan Dijaga *Server* (v5.4.2)

Tombol pemutus wajib ditahan: **Eksekusi Isolasi** 0,6 detik, **Isolasi Darurat** 1,5 detik. Sebelum v5.4.2 aturan ini hanya dijaga peramban. Kini:

1. Saat tombol **mulai** ditahan, peramban meminta token sekali pakai: `POST /api/tahan {"layanan_id", "tujuan": "isolasi" | "darurat"}` (hanya Operator). Token terikat pada akun, layanan, dan tombol, berlaku 15 detik; menekan ulang membuang token lama.
2. Eksekusi membawa token itu. *Server* menolak dengan kode 428 bila token tidak ada, sudah dipakai, milik akun/layanan/tombol lain, kedaluwarsa, atau eksekusi datang lebih cepat dari 0,5 detik (isolasi darurat 1,4 detik; toleransi jaringan 0,1 detik dari lama tombol).
3. Aturan ini berlaku untuk **semua** jalur pemutus: aksi gabungan `isolasi`, setiap tindakan pemutus satuan di `POST /api/soar/jalankan`, dan `POST /api/soar/darurat`. Tindakan non-pemutus (amankan bukti, pemulihan) tidak perlu ditahan.
4. Lama tahan dicatat di log audit (`tahan_ms`).

Batasnya ditulis di §2.7: ini menegakkan doktrin, bukan pengaman terhadap skrip yang sengaja menunggu. Dikunci `tests/test_tahan.py` dengan batas waktu asli.

4. Instruksi Pemasangan (*Deployment*)

4.1 Menjalankan *Server*

```
# 1. Masuk ke folder proyek
cd nusantara-shield-v5.4.2

# 2. Buat lingkungan Python lokal (sekali saja)
python3 -m venv .venv
source .venv/bin/activate          # Windows: .venv\Scripts\activate

# 3. Pasang dependensi (satu-satunya langkah yang butuh internet)
pip install -r requirements.txt

# 4. Nyalakan server
python -m uvicorn app.main:app --host 127.0.0.1 --port 8000 --no-access-log --no-server-header
```

Buka **http://127.0.0.1:8000**. Sandi akun bawaan tercetak di terminal saat *server* menyala.

4.2 Menjalankan Uji Otomatis

```
./run_tests.sh          # macOS / Linux
run_tests.bat           # Windows
```

Cuplikan **keluaran asli** `./run_tests.sh` (tiga uji pertama tiap kelompok ditampilkan; daftar lengkap tercetak di terminal):

```
operator@posko-siber: ~/nusantara-shield-v5.4.2 — ./run_tests.sh

operator@posko-siber:~/nusantara-shield-v5.4.2$ ./run_tests.sh
▶ Menjalankan uji otomatis Nusantara Shield v5.4.2 — setiap uji tampil satu baris beserta hasilnya
============================= test session starts ==============================
platform linux -- Python 3.13.16, pytest-9.1.1, pluggy-1.7.0 -- /usr/bin/python3
rootdir: …/nusantara-shield-v5.4.1
configfile: pytest.ini
testpaths: tests
plugins: anyio-4.15.1
collecting ... collected 485 items
── ▶ AI lokal: deteksi anomali Isolation Forest, luring, dengan alasan yang bisa dibaca ──
test_ai.py::test_model_dilatih_lokal_dengan_benih_tetap_dan_hasilnya_dapat_diaudit PASSED [0%]
test_ai.py::test_lalu_lintas_wajar_tidak_memicu_alarm_palsu PASSED [0%]
test_ai.py::test_latihan_modbus_menaikkan_genset_ke_waspada_tanpa_kabar_cti PASSED [0%]
   … 7 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Manajemen akun: pendaftaran pengamat/operator, dasbor akun operator ──
test_akun.py::test_pengamat_mendaftar_sendiri_lalu_login_dan_hanya_bisa_melihat PASSED [2%]
test_akun.py::test_operator_mandiri_tanpa_kode_atau_kode_salah_ditolak PASSED [2%]
test_akun.py::test_operator_dengan_kode_undangan_sah_bisa_mengubah PASSED [2%]
   … 24 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Intelijen ancaman (CTI) & SOAR: prediksi, pengerasan, isolasi, peta ──
test_cti_soar.py::test_loket_baru_wajib_login_dan_hanya_operator[/api/cti/siarkan-data0] PASSED [7%]
test_cti_soar.py::test_loket_baru_wajib_login_dan_hanya_operator[/api/soar/jalankan-data1] PASSED [8%]
test_cti_soar.py::test_loket_baru_wajib_login_dan_hanya_operator[/api/soar/perketat-data2] PASSED [8%]
   … 15 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Mesin Deteksi Aturan: login gagal berulang, login tembus, pemindaian port (ambang terbuka) ──
test_deteksi.py::test_ambang_terbuka_sesuai_dokumentasi PASSED [11%]
test_deteksi.py::test_temuan_muncul_tepat_pada_gagal_kedelapan PASSED [11%]
test_deteksi.py::test_login_gagal_ambang_tepat PASSED [11%]
   … 21 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Drill kesiapan: log cerita sintetis lewat aturan yang sama, nilai dari jejak tercatat ──
test_drill.py::test_pengamat_melihat_katalog_tetapi_tidak_bisa_memulai_atau_menjawab PASSED [16%]
test_drill.py::test_tanpa_login_ditolak PASSED [16%]
test_drill.py::test_kode_drill_dan_kolom_asing_ditolak PASSED [16%]
   … 33 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Impor log luring: auth.log, firewall, CSV, Wazuh alerts.json, Suricata eve.json; aturan sama, dua kunci utuh
──
test_impor_log.py::test_auth_log_openssh_dibaca_tanpa_nama_akun PASSED [23%]
test_impor_log.py::test_log_firewall_ufw_menjadi_koneksi_dan_aset_dikenali_dari_port PASSED [24%]
test_impor_log.py::test_csv_berkepala_dan_alamat_ip_aset_dipetakan PASSED [24%]
   … 35 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Insiden dari temuan log asli: keputusan Operator, aset dan kronologi dari temuan, doktrin sama ──
test_insiden_temuan.py::test_impor_saja_tidak_membuka_insiden_tetapi_mengusulkannya PASSED [31%]
test_insiden_temuan.py::test_insiden_dari_temuan_memakai_aset_dan_kronologi_temuan_bukan_templat PASSED [31%]
test_insiden_temuan.py::test_label_attck_insiden_mengikuti_aturan_temuan PASSED [32%]
   … 11 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Kamus istilah: tidak ada label yang tertanam di luar app/istilah.py ──
test_istilah.py::test_tidak_ada_label_tertanam_di_luar_kamus[Amankan bukti] PASSED [34%]
test_istilah.py::test_tidak_ada_label_tertanam_di_luar_kamus[BUKTI DIAMANKAN] PASSED [34%]
test_istilah.py::test_tidak_ada_label_tertanam_di_luar_kamus[Buku Rantai Bukti] PASSED [35%]
   … 38 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Keamanan & akses: login, peran, batas laju, header, batas ukuran kiriman, log audit ──
test_keamanan.py::test_semua_endpoint_wajib_login[get-/api/layanan-None] PASSED [43%]
test_keamanan.py::test_semua_endpoint_wajib_login[post-/api/indikator/cari-data1] PASSED [43%]
test_keamanan.py::test_semua_endpoint_wajib_login[post-/api/simulasi-data2] PASSED [43%]
   … 35 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Rantai komando & laporan: isolasi pre-authorized, LAPSIT, Quick Call ──
test_komando.py::test_quick_call_wajib_login_dan_hanya_operator PASSED [50%]
test_komando.py::test_quick_call_menolak_input_aneh[data0] PASSED [51%]
test_komando.py::test_quick_call_menolak_input_aneh[data1] PASSED [51%]
   … 19 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Linimasa 60 menit (data latihan), pita anomali AI per aset, KPI MTTC dan insiden ──
test_linimasa.py::test_posko_baru_berisi_60_menit_data_latihan_yang_bersih PASSED [55%]
test_linimasa.py::test_data_latihan_berbenih_tetap PASSED [55%]
test_linimasa.py::test_setiap_60_detik_menjadi_satu_titik_posko PASSED [55%]
   … 3 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Sinergi IT/OT: kabar Modbus menaikkan pengendali genset ke WASPADA ──
test_ot.py::test_genset_terdaftar_sebagai_aset_ot_di_topologi_dan_radar PASSED [56%]
test_ot.py::test_kabar_modbus_menaikkan_genset_ke_waspada_sebelum_serangan PASSED [56%]
test_ot.py::test_perketat_genset_menurunkan_peluang_di_bawah_ambang PASSED [57%]
   … 3 uji lain dalam kelompok ini · semuanya PASSED
```

```
── ▶ Aturan OT, label MITRE ATT&CK, label sumber data, dan pengesahan dua tanda tangan LAPSIT ──
test_ot_mitre_lapsit.py::test_aturan_ot_terbuka_sesuai_dokumentasi PASSED [57%]
test_ot_mitre_lapsit.py::test_jalur_ot_resmi_bukan_temuan PASSED [58%]
test_ot_mitre_lapsit.py::test_koneksi_ot_tanpa_izin_menjadi_temuan_sekali_per_episode PASSED [58%]
   … 20 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Paket pasang luring: sidik jari SHA-256, pemasangan tanpa internet ──
test_paket_luring.py::test_paket_utuh_lolos_pemeriksaan PASSED [62%]
test_paket_luring.py::test_satu_bait_berubah_langsung_ditolak PASSED [62%]
test_paket_luring.py::test_pemasang_menerima_paket_utuh PASSED [63%]
   … 5 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Paket pasang Ubuntu 24.04: tanda tangan Ed25519, manifest SHA-256, pemasang menolak paket yang diubah ──
test_paket_ubuntu.py::test_paket_tersusun_lengkap_terkunci_dan_tanpa_rahasia PASSED [64%]
test_paket_ubuntu.py::test_payload_deterministik_dari_commit_dan_wheel_yang_sama PASSED [64%]
test_paket_ubuntu.py::test_pembuat_paket_menolak_kunci_privat_wheel_ganda_dan_versi_aneh PASSED [64%]
   … 21 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Rantai bukti forensik: bukti sebelum isolasi, isolasi darurat, cocok hash ──
test_rantai_bukti.py::test_setiap_playbook_diawali_amankan_bukti_sebelum_pemutusan[ransomware] PASSED [69%]
test_rantai_bukti.py::test_setiap_playbook_diawali_amankan_bukti_sebelum_pemutusan[ddos] PASSED [69%]
test_rantai_bukti.py::test_setiap_playbook_diawali_amankan_bukti_sebelum_pemutusan[sabotase_ot] PASSED [69%]
   … 34 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Saksi Berjenjang Luring: posko → satuan atasan → jenjang di atasnya; mundur atau bercabang ditolak ──
test_saksi.py::test_tanda_tangan_python_murni_sama_dengan_cryptography PASSED [76%]
test_saksi.py::test_alat_atasan_hanya_pustaka_bawaan PASSED [77%]
test_saksi.py::test_kunci_jenjang_izin_600_dan_tidak_pernah_ditimpa PASSED [77%]
   … 31 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Tahan dijaga server: token sekali pakai, batas 0,6 / 1,5 detik, semua jalur pemutus ──
test_tahan.py::test_tanpa_token_ditolak_428 PASSED [83%]
test_tahan.py::test_dilepas_terlalu_cepat_ditolak_lalu_ditahan_penuh_diterima_dan_tercatat PASSED [84%]
test_tahan.py::test_token_sekali_pakai_dan_terikat_akun_layanan_tujuan PASSED [84%]
   … 8 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Telemetri & siaran: panel bergerak, dapur tunggal, tambalan delta ──
test_telemetri.py::test_telemetri_wajib_login[/api/telemetri] PASSED [86%]
test_telemetri.py::test_telemetri_wajib_login[/api/telemetri/siaran] PASSED [86%]
test_telemetri.py::test_pengamat_boleh_melihat_tetapi_tidak_memicu PASSED [86%]
   … 16 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Titik periksa Ed25519: kunci berevolusi, auditor memeriksa dengan kunci publik saja ──
test_titik_periksa.py::test_ed25519_murni_sama_dengan_cryptography PASSED [90%]
test_titik_periksa.py::test_alat_auditor_tidak_mengimpor_pustaka_luar PASSED [90%]
test_titik_periksa.py::test_mode_demo_tanpa_kunci_hmac_tidak_aktif PASSED [90%]
   … 13 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Triase & Kesiapan Siber: penutupan peringatan beralasan, nilai A–E terbuka ──
test_triase_kesiapan.py::test_huruf_mengikuti_batas_terbuka PASSED [93%]
test_triase_kesiapan.py::test_nilai_awal_mengikuti_rumus_terbuka PASSED [93%]
test_triase_kesiapan.py::test_kabar_ancaman_menurunkan_kedua_sub_skor_dan_perketat_memulihkannya PASSED [93%]
   … 13 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Verifikasi audit tanpa server: CLI mandiri menghitung ulang rantai HMAC log audit dan buku bukti ──
test_verifikasi_audit.py::test_log_asli_dinyatakan_utuh_dan_sidik_jari_terakhir_sama_dengan_server PASSED [96%]
test_verifikasi_audit.py::test_isi_entri_diubah_tertangkap_beserta_nomornya PASSED [96%]
test_verifikasi_audit.py::test_entri_dihapus_di_tengah_tertangkap PASSED [97%]
   … 9 uji lain dalam kelompok ini · semuanya PASSED
── ▶ Satu sumber versi: dasbor, LAPSIT, dan paket memakai app/versi.py; nama peran berhuruf kapital ──
test_versi.py::test_format_versi PASSED [99%]
test_versi.py::test_alat_pengemas_membaca_versi_yang_sama PASSED [99%]
test_versi.py::test_tidak_ada_label_versi_tertulis_langsung PASSED [99%]
   … 2 uji lain dalam kelompok ini · semuanya PASSED

═══════ 485 passed in 62.88s ═══════
```

Setiap uji tampil satu baris beserta hasilnya. Target: `485 passed`.

Kelompok uji	Jumlah	Yang dijamin
Keamanan dan akses	38	*Login*, peran, batas laju, *header* keamanan, batas ukuran kiriman, log audit antimanipulasi
Rantai bukti forensik	37	Bukti sebelum isolasi, isolasi darurat beralasan, pemulihan wajib cocok *hash*; berlaku juga untuk Sabotase OT
Kamus istilah	41	Seluruh label (kini istilah satuan) berasal dari satu kamus
Rantai komando dan laporan	22	Isolasi praotorisasi, LAPSIT tepat sekali, nomor tidak berulang

Kelompok uji	Jumlah	Yang dijamin
Telemetri dan siaran	19	Satu dapur untuk semua layar, ralat delta identik dengan *server*
Intelijen ancaman dan Security Orchestration, Automation and Response (SOAR)	18	Peringatan dini, pengerasan aset, isolasi bertahap
Manajemen akun	27	Pendaftaran aman, pemisahan peran, dasbor akun Operator, wajib ganti sandi awal
Mesin Deteksi Aturan	24	Ambang terbuka dikunci (gagal ke-7 belum, ke-8 terdeteksi); jendela waktu; tanpa penggandaan; hanya menaikkan WASPADA; Perketat dan triase; label isolasi memakai nama Operator dan nomor bukti sebenarnya
Linimasa dan KPI	6	Data latihan bersih dan berbenih tetap; satu titik per 60 detik; tanda insiden; pita AI dan berakhirnya; KPI dari kejadian nyata
AI lokal	10	Model dilatih lokal dengan benih tetap; tanpa alarm palsu; Modbus tak wajar → WASPADA beserta alasan; gabungan dengan CTI; Perketat; penilaian dalam milidetik; berjalan tanpa jaringan
Paket pasang luring	8	Daftar sidik jari SHA-256 mencakup setiap berkas; satu bait berubah, berkas hilang, berkas selundupan, atau jalur keluar paket langsung ditolak; pemasangan memakai `--no-index`; paket tanpa `.env/.venv/data`
Impor log luring	38	auth.log, firewall, CSV, Wazuh alerts.json, dan Suricata eve.json dibaca tanpa nama akun; jam Modbus dari stempel sensor; baris tidak sah dilewati dan dihitung; aturan yang sama dengan latihan; dua kunci utuh; log audit tanpa isi log; hanya jalur impor boleh ≈2 MB dan hanya dengan token; batas laju
Aturan OT, label MITRE ATT&CK, label sumber data, pengesahan LAPSIT	23	Jalur OT resmi dan perintah baca bukan temuan; jendela pemeliharaan 22.00–02.00 diuji per jam; rantai IT → OT; dua kunci utuh (genset hanya WASPADA, tanpa insiden, bukti, atau isolasi); setiap aturan dan skenario berlabel ATT&CK; AI tanpa label; setiap peringatan menulis sumber datanya; LAPSIT memuat teknik ATT&CK dan dua tanda tangan
Sinergi IT/OT	6	Genset (Modbus 502) terdaftar; kabar Modbus → WASPADA; Perketat; tanpa alarm palsu IT ⇄ OT; Sabotase OT: bukti → putus jalur ≈1,2 dtk, genset tetap menyala; pemulihan terkunci bila *hash* beda
Verifikasi audit tanpa *server*	12	CLI mandiri menghitung ulang rantai HMAC log audit dan Buku Rantai Bukti; isi diubah, entri dihapus, entri dari log lain disisipkan, baris rusak, dan kunci salah tertangkap beserta letaknya; `--cocokkan` menangkap log yang dipotong di ujung; kunci tidak pernah dicetak; tanpa kode aplikasi dan tanpa jaringan
Triase dan Kesiapan Siber	16	Rumus Kesiapan Siber terbuka (dua sub-skor, nilai = yang lebih rendah, huruf A–E); kabar ancaman menurunkan nilai, Perketat memulihkannya; penutupan peringatan wajib beralasan dan hanya untuk Operator
Paket pasang Ubuntu 24.04	24	*Payload* deterministik dan bertanda tangan Ed25519; satu bita berubah, kunci lain, atau berkas tak tercatat → pemasangan ditolak; versi turun ditolak, `--kembali` dan `--hapus` berjalan
Titik periksa Ed25519	16	Ed25519 murni di alat auditor sama dengan pustaka *cryptography*; akar dibuat sekali dan dicatat; entri diubah, log dipotong, akar salah, titik periksa ditandatangani ulang kunci curian → tertangkap; kunci lama tidak tersisa di disk
Saksi Berjenjang Luring	34	Penandatangan Ed25519 Python murni identik dengan *cryptography*; saksi diterima, dicatat, Tanda Terima sah; saksi lama sesudah saksi baru → digulung mundur; cabang bertanda tangan sah → bercabang; berkas disunting, pengirim tak diharapkan, Buku Saksi sendiri disunting → ditolak; jenjang bawah menulis ulang bukunya → tertangkap di jenjang atas; auditor `--saksi` menangkap log dan titik periksa yang digulung mundur bersama; `POST /api/saksi` hanya Operator, 409 di mode demo
Insiden dari temuan log asli	14	Impor saja tidak membuka insiden; aset, kronologi, ATT&CK, SHA-256 berkas dari temuan, tanpa templat; doktrin bukti → putus sama; Drill, latihan, triase, ganda, Pengamat ditolak
Tahan dijaga *server*	11	Token sekali pakai terikat akun, layanan, tombol, insiden; batas 0,5 / 1,4 detik; semua jalur pemutus termasuk centang manual; tercatat di log audit

Kelompok uji	Jumlah	Yang dijamin
Drill Kesiapan	36	Log cerita sintetis (auth.log dan Suricata eve.json) lewat aturan yang sama; aturan yang diam dilaporkan; kunci jawaban tidak dikirim sebelum dijawab; nilai dari jejak tercatat (bukti 30/15/0, ambang MTTC terbuka); cerita OT selalu di luar jendela pemeliharaan; hanya Operator; tercetak di LAPSIT sebagai LATIHAN
Satu sumber versi	5	Dasbor, kop LAPSIT, nama zip, dan paket memakai `app/versi.py`; label versi tertulis langsung → gagal; nama peran tampil berhuruf kapital

4.3 Mengemas untuk Distribusi

```
python tools/kemas_rilis.py      # → dist/nusantara-shield-v5.4.2.zip (≈ 17 MB, termasuk dokumen PDF)
```

Paket dibuat **tanpa** `.venv`, `.env`, data operasional, dan *cache*. Penerima cukup mengulang langkah 4.1.

4.4 Pemasangan Luring (*Air-gapped*)

Untuk posko tanpa internet, kode dan seluruh pustaka dikemas menjadi satu zip beserta daftar sidik jari SHA-256 (`SHA256SUMS`). Sidik jari daftar dan sidik jari zip dicatat di **berita acara serah terima paket**, sejalan dengan rantai bukti.

```
# 1) Di komputer yang terhubung internet (sekali saja; pilih platform posko):
python tools/kemas_luring.py --platform win_amd64 --python 3.12          # posko Windows 64-bit
python tools/kemas_luring.py --platform macosx_14_0_arm64 --python 3.12   # posko Mac Apple Silicon
python tools/kemas_luring.py                                              # posko sama dengan
komputer ini
#    → dist/nusantara-shield-v5.4.2-luring-<platform>.zip + dua sidik jari untuk berita acara

# 2) Di posko tanpa internet: ekstrak zip, masuk ke foldernya, lalu
python pasang_luring.py --periksa-saja    # cocokkan sidik jari SHA256SUMS dengan berita acara
python pasang_luring.py                   # buat .venv, pasang dari wheels/ (--no-index), jalankan
uji
```

Pemeriksaan di posko	Akibat
Sidik jari setiap berkas dicocokkan dengan `SHA256SUMS`	Satu bait berubah, berkas hilang, berkas tambahan, atau jalur keluar folder paket → pemasangan **dihentikan**
`pip install --no-index --find-links wheels`	pip dilarang menghubungi internet; hanya memakai pustaka di paket
Uji otomatis dijalankan setelah pemasangan	Bukti bahwa pemasangan utuh (semua uji `passed`)

Terverifikasi: paket untuk Linux dibuat lalu dipasang dengan jaringan diblokir; hasilnya `254 passed` (26 Okt 2026, versi sebelum aturan OT). Pengunduhan pustaka untuk Windows (`win_amd64`) dan Mac Apple Silicon (`macosx_14_0_arm64`) juga berhasil. **Batas:** versi Python di posko harus sama dengan `--python`; ukuran paket ≈50–80 MB per platform; zip ini belum bertanda tangan digital (untuk Ubuntu 24.04 lihat paket bertanda tangan di bawah).

Paket Ubuntu 24.04 LTS bertanda tangan (sejak v5.2.0)

Untuk *server* Ubuntu 24.04 LTS x86_64, `SHA256SUMS` ditandatangani **Ed25519**. Kunci privat dibuat dan disimpan terenkripsi (PKCS#8, kata sandi minimal 16 karakter, izin 600) hanya di komputer pembuat rilis (`tools/kunci_rilis.py`); repo hanya memuat kunci publik (`kunci/`). Penandatanganan memakai pustaka `cryptography` di komputer pembuat rilis; verifikasi di Ubuntu memakai `openssl` bawaan, jadi tidak ada pustaka tambahan yang harus dipercaya sebelum paket terverifikasi.

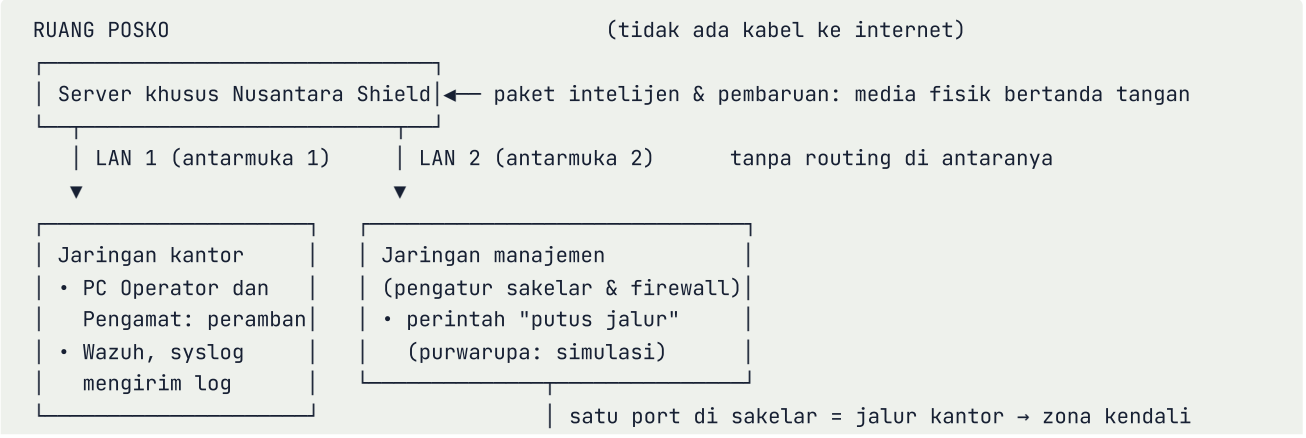
Langkah `pasang.sh`	Pemeriksaan	Gagal → kode
1. Prasyarat	Root, Ubuntu 24.04, x86_64, `/usr/bin/python3.12` (3.12, modul `venv`, `tarfile.data_filter`), OpenSSL 3, `sha256sum`	20, tanpa perubahan
2. Keaslian	Sidik jari kunci publik paket = yang tertanam di `pasang.sh`; `openssl pkeyutl -verify -rawin` atas `SHA256SUMS`; format setiap baris; `sha256sum -c --strict`	10, tanpa perubahan
3. Isi payload	`payload.tar.gz` = manifest; setiap anggota tar diperiksa **tanpa diekstrak**: tidak absolut, tanpa `..`, hanya berkas/folder biasa, harus tercatat, tidak ganda	11, tanpa perubahan
4. Ekstraksi	Ke folder sementara dengan filter `data` Python; SHA-256 dan ukuran **setiap** berkas dicocokkan dengan manifest; berkas lebih/kurang ditolak	12, folder sementara dihapus
5. Lingkungan	`python3.12 -m venv --without-pip`; `pip --no-index --require-hashes` dari wheel di paket; uji asap `/api/health`; `--uji` menjalankan seluruh uji	13, rilis baru dihapus
6. Pasang	Pengguna sistem `nshield`; `/etc/nusantara-shield/env` 0640 dibuat sekali (kunci audit 256-bit dan sandi acak, tidak dicetak); layanan systemd; tautan `kini` diganti atomik; cek kesehatan, gagal → kembali ke rilis sebelumnya	14

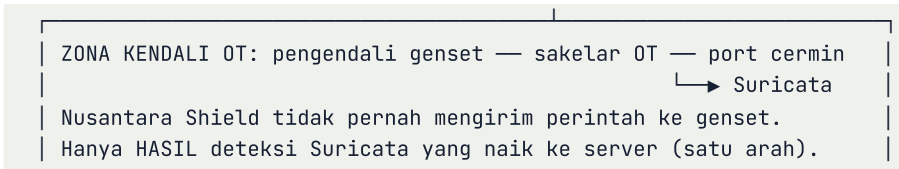
Layanan `nusantara-shield.service` berjalan sebagai `nshield` dengan `ProtectSystem=strict`, `NoNewPrivileges`, tanpa *capability*, `PrivateTmp/PrivateDevices`, `RestrictAddressFamilies`, dan `SystemCallFilter=@system-service`; satu-satunya folder yang boleh ditulis adalah `/var/lib/nusantara-shield`. Verifikasi log audit di *server*: `sudo ns-verifikasi-audit --cocokkan <sidik jari LAPSIT>`.

Terverifikasi (29 Okt 2026): paket dibuat dari commit bersih dengan wheel Linux asli (36 wheel, 135 berkas payload, ≈83 MB), ditandatangani dengan kunci uji sementara, lalu dipasang **sebagai root di Ubuntu 24.04 (kontainer) dengan jaringan diputus** (`unshare -n`, hanya *loopback*). Hasil: semua pemeriksaan lolos, uji asap `/api/health` "ok", dan **333 passed** dijalankan dari venv terpasang. Layanan dijalankan sebagai `nshield` dengan perintah dan env yang sama dengan berkas layanan: *login*, ekspor LAPSIT, dan `ns-verifikasi-audit` (UTUH) berhasil. Tanpa `/usr/bin/python3.12`, pemasang berhenti dengan kode 20 tanpa mengubah apa pun. Ke-14 pemeriksaan pengaman di `pasang.sh` diuji mutasi: setiap pemeriksaan dimatikan bergantian, dan sedikitnya satu uji gagal. **Batas:** systemd tidak berjalan di kontainer, jadi berkas layanan dan pengerasannya baru diperiksa `systemd-analyze verify`; uji di VM Ubuntu sungguhan dijadwalkan pada QA akhir. `pasang.sh` tidak bisa membuktikan keaslian dirinya sendiri, sehingga Operator tetap memeriksa sidik jari `.tar`, sidik jari kunci, dan tanda tangan secara manual (`BACA-SAYA.txt`).

4.5 Penempatan di Jaringan Satuan (Rancangan)

Status: rancangan, belum diuji di jaringan satuan. "Luring" berarti tidak bergantung pada internet untuk dipasang maupun dijalankan; bukan berarti terputus dari jaringan lokal satuan. Di satuan, Nusantara Shield berperan seperti **ruang pemantau**: sensor yang sudah ada (Wazuh, Suricata, log *firewall*) adalah kameranya, dan sakelar terkelola adalah panel kuncinya. *Server* tidak menarik kabel ke setiap perangkat.





Sambungan	Arah	Isi	Aturan
Jaringan kantor (LAN 1)	masuk	Dasbor dibuka dari peramban PC Operator dan Pengamat; log dari Wazuh, *syslog*, auth.log	*Server* hanya menerima. Tidak ada perintah ke komputer kantor
Jaringan manajemen (LAN 2)	keluar	Perintah ke sakelar terkelola dan *firewall*	Hanya setelah bukti diamankan dan tombol ditahan (§3.1, §3.7). Di purwarupa masih simulasi
Zona kendali OT	masuk, satu arah	Hasil deteksi Suricata dari port cermin (salinan lalu lintas)	Baca-saja. Tidak ada kabel atau perintah dari *server* ke pengendali genset
Internet	—	—	Tidak ada. Kabar ancaman dan pembaruan lewat media fisik bertanda tangan, atau arus satu arah (*data diode*) dari jaringan satuan atasan

Memutus jalur, bukan mematikan genset. Antara jaringan kantor dan zona kendali ada satu jalur (satu port di sakelar) agar teknisi bisa memantau genset dari kantor. Bila penyerang masuk lewat komputer kantor, yang ditutup adalah jalur itu. Genset tetap menyala dan dikendalikan teknisi dari panel lokal di gedung genset; setelah konfigurasi pengendali dicocokkan, jalur dibuka kembali (playbook Sabotase OT, NIST SP 800–82). Mematikan genset justru tujuan penyerang.

***Server* tidak menjadi jembatan.** Dua antarmuka jaringan dipisah tanpa *routing* (`net.ipv4.ip_forward=0`) dan dibatasi *firewall* lokal: dari jaringan kantor hanya port dasbor dan penerimaan log yang dibuka; ke jaringan manajemen hanya alamat sakelar dan *firewall* yang dituju. Bila *server* dibobol, penyerang tidak otomatis bisa menyeberang lewat *server* itu.

Wujud "*server* khusus". Satu komputer yang tugasnya hanya menjalankan Nusantara Shield: *mini-PC*, komputer *desktop*, *server* rak, atau laptop yang dikhususkan untuk itu. Kebutuhannya §1.1 (Ubuntu 24.04, 2 inti, 512 MB memori bebas, 1 GB penyimpanan). Yang membuatnya khusus adalah cara pakainya: tetap di ruang posko yang terkunci, menyala terus (idealnya dengan UPS), tidak dipakai untuk surel atau berselancar, dan menjadi tanggung jawab satuan. Operator dan Pengamat bekerja dari komputer masing-masing lewat peramban. Data, log audit, dan bukti tersimpan di *server*, jadi tidak hilang bila komputer Operator dimatikan atau diganti. Pada demo lomba, keduanya kebetulan dijalankan di satu laptop yang sama.

Urutan peta jalan konektor. Semuanya baca-saja dan berjalan di jaringan lokal:

1. **Sudah berjalan:** impor berkas luring (auth.log, UFW, CSV, Wazuh `alerts.json`, Suricata `eve.json`), lalu Buka Insiden dari temuannya (§3.6).
2. **Berikutnya:** konektor lokal yang membaca terus-menerus: API Wazuh, Suricata `eve.json` yang terus bertambah, dan penerima *syslog*. Pengurainya sama dengan jalur impor (sudah tahan berkas beracun). Akun API baca-saja, sertifikat TLS dipatok, tanpa *active response*.
3. **Paket Intelijen Bertanda Tangan:** pembaruan indikator dan ambang aturan lewat media fisik, diverifikasi Ed25519 seperti paket rilis.
4. **Perintah sungguhan ke sakelar terkelola** lewat jaringan manajemen, tetap dengan Dua Kunci, bukti lebih dulu, dan tombol ditahan.

5. Cara Penggunaan Singkat

1. **Masuk.** Buka alamat *server* di peramban, lalu masuk sebagai `operator` (boleh bertindak) atau `pengamat` (melihat dan mencetak LAPSIT). Sandi diambil dari pengaturan `NS_OPERATOR_PASSWORD` dan `NS_VIEWER_PASSWORD`, atau dicetak di terminal saat *server* menyala.
2. **Baca situasi.** Kotak Postur, Topologi Internal atau Peta Global, Radar Anomali, dan pita Radio CTI menunjukkan kondisi seluruh aset.
3. **Latih skenario.** Pada panel Latihan, pilih target layanan dan skenario (*Ransomware*, Distributed Denial of Service (DDoS), Cadangan mati, atau Sabotase OT). Tombol latihan OT menyiarkan kabar Modbus untuk melihat peringatan dini; tombol **Latihan AI** menyuntik lalu lintas tak wajar untuk melihat AI lokal bekerja.
4. **Tangani insiden.** Di Action Center, tahan tombol **EKSEKUSI ISOLASI** selama 0,6 detik. Bukti disegel lebih dulu, lalu pemutusan berjalan dan LAPSIT terbit.
5. **Pulihkan dan laporkan.** Centang langkah *playbook* yang tersisa; tombol Pulihkan terbuka setelah sidik jari bukti cocok ulang. LAPSIT dapat diekspor ke PDF dari tab "Audit & LAPSIT".

---

6. Riwayat Pengembangan dan Atribusi

Deklarasi (Rulebook bagian G, Ketentuan Karya). Seluruh kode dikembangkan sejak **15 Oktober 2026**, setelah publikasi program (12 Oktober 2026), dari versi 1 hingga versi 5.1 yang diserahkan. Selain pustaka sumber terbuka di bawah ini, tidak ada kode dari karya pihak lain atau karya tim yang dibuat sebelum tanggal tersebut.

Atribusi (Rulebook bagian G).

Komponen	Kegunaan	Lisensi
FastAPI (beserta Starlette dan Pydantic)	Kerangka *server* dan validasi masukan	MIT dan BSD-3-Clause
Uvicorn	*Server* web asinkron	BSD-3-Clause
ReportLab	Ekspor LAPSIT ke PDF	BSD
scikit-learn dan **NumPy**	AI lokal: model *Isolation Forest* untuk deteksi anomali	BSD-3-Clause
pytest dan **HTTPX**	Uji otomatis	MIT dan BSD-3-Clause
Mermaid dan **Playwright (Chromium)**	Hanya untuk menggambar diagram dan mencetak dokumen ini; tidak dipakai aplikasi	MIT, Apache-2.0, dan BSD-3-Clause
Claude (Anthropic)	Asisten AI untuk membantu menulis kode dan dokumentasi; tidak dipanggil oleh aplikasi (AI di dalam aplikasi adalah model lokal scikit-learn di atas)	Layanan komersial
MITRE ATT&CK® (Enterprise dan ICS)	Label teknik pada peringatan dan LAPSIT; tabel statis di `app/mitre.py`, pemetaan oleh tim sendiri	Merek dagang The MITRE Corporation; dipakai sebagai rujukan
Gemini (Google)	Eksplorasi awal konsep logo; logo final digambar ulang tim sebagai vektor SVG dan tidak memuat gambar hasil AI	Layanan komersial
Inter dan **JetBrains Mono**	Huruf pada logo horizontal dan spanduk README	SIL Open Font License 1.1
Blok alamat IP RFC 5737	Data latihan sintetis	Standar terbuka IETF

Rujukan kerangka. Purbo, O. W., dan Lumy, G. D. (2025). *Cyber Warfare & Pertahanan Siber Indonesia*. Peraturan Presiden Nomor 82 Tahun 2022 tentang Pelindungan Infrastruktur Informasi Vital. National Institute of Standards and Technology (NIST) SP 800–82. International Organization for Standardization/International Electrotechnical

Commission (ISO/IEC) 27037:2012 tentang penanganan bukti digital; alur bukti dan buku berantai HMAC **mengikuti prinsipnya**, belum diaudit terhadap standar ini. National Institute of Standards and Technology (2024), *The NIST Cybersecurity Framework (CSF) 2.0* (CSWP 29), dipakai untuk pemetaan di §2.6; pemetaan dilakukan tim sendiri, bukan sertifikasi.

Lampiran: Kamus Istilah

Kamus ini untuk pembaca yang tidak berlatar militer atau teknis. Istilah diurutkan menurut abjad.

Istilah	Kepanjangan atau arti	Penjelasan sederhana
Air-gapped	Jaringan terpisah dari internet	Jaringan yang secara fisik tidak tersambung ke internet sama sekali.
Cyber drill	Latihan tanggap insiden	Simulasi insiden dengan skenario khusus satu organisasi; tim teknis berlatih urutan tindakan, lalu kecepatan dan ketepatannya dinilai. Di sistem ini: tab Drill Kesiapan.
Explainability	Keterjelasan	AI wajib menyebut alasannya dalam bahasa manusia, misalnya "perintah tulis Modbus 10× normal".
False Positive	Positif Palsu	Alarm yang ternyata bukan ancaman. Operator menutupnya dengan alasan tertulis; penutupan tercatat permanen dan tidak menghapus apa pun.
***Hash* / SHA-256**	Sidik jari digital	Rumus yang mengubah isi berkas menjadi 64 karakter. Isi berubah satu huruf, sidik jarinya berubah total.
Human-in-the-loop	Manusia tetap memegang keputusan	Mesin hanya menyarankan; tindakan memutus jaringan harus disetujui Operator.
Local inference	Perhitungan AI di komputer sendiri	Model dijalankan di *server* sendiri, bukan lewat layanan di internet. Berbeda dengan *air-gapped*.
Machine learning	Pembelajaran mesin	Komputer belajar pola dari contoh data, bukan dari aturan yang ditulis satu per satu.
On-premise	Terpasang di tempat sendiri	Dipasang di perangkat milik satuan, bukan disewa dari layanan awan.
Playbook	Buku panduan langkah	Urutan tindakan baku untuk setiap jenis insiden.
Port	Pintu layanan	Nomor "pintu" di perangkat; tiap layanan punya nomornya sendiri.
Ransomware	Program penyandera data	Program jahat yang mengunci data lalu meminta tebusan.
Server	Komputer pelayan	Komputer yang melayani komputer lain; di sini tempat Nusantara Shield berjalan.
Tabletop exercise (TTX)	Latihan diskusi skenario	Latihan untuk pimpinan: yang diuji keputusan saat insiden, bukan kemampuan teknis. Belum dibangun; masuk peta jalan.
Webhook	Panggilan otomatis	Pesan otomatis dari satu sistem ke sistem lain, misalnya perintah ke sakelar jaringan.
AAR	*After-Action Review* (tinjauan pascatindakan)	Rapat evaluasi setelah insiden: apa yang terjadi, apa penyebabnya, dan apa yang diperbaiki.
Action Center	Pusat tindakan	Panel di dasbor tempat Operator melihat insiden dan menekan tombol isolasi.
AI lokal	Kecerdasan buatan yang berjalan di komputer sendiri	Model yang dilatih dan dihitung di *server* satuan, tanpa mengirim data ke internet.

Istilah	Kepanjangan atau arti	Penjelasan sederhana
Alamat IP	Alamat *Internet Protocol*	Nomor unik setiap perangkat di jaringan, seperti nomor rumah.
API	*Application Programming Interface*	"Loket" tempat layar dan *server* saling meminta data.
Aset	Barang yang dilindungi	Perangkat atau sistem penting: komputer, *server*, basis data, genset.
ASGI	*Asynchronous Server Gateway Interface*	Antarmuka standar antara *server* web dan aplikasi Python; di sini gerbang yang menolak kiriman terlalu besar sebelum menyentuh logika.
ATT&CK	*Adversarial Tactics, Techniques, and Common Knowledge* (MITRE)	Katalog publik taktik dan teknik penyerang; dipakai untuk melabeli peringatan, misalnya T0855.
Bintara Siber	Prajurit Tentara Nasional Indonesia Angkatan Darat (TNI AD) berpangkat bintara di bidang siber	Calon Operator harian sistem ini di satuan.
BSSN	Badan Siber dan Sandi Negara	Lembaga keamanan siber nasional.
CDN	*Content Delivery Network*	Layanan luar untuk memuat huruf atau skrip situs web. Nusantara Shield tidak memakainya.
CDOC	Cyber Defense Operation Center	Pusat operasi pertahanan siber di tingkat satuan.
CPU	Central Processing Unit	Otak komputer; persentasenya menunjukkan seberapa sibuk *server*.
CSF 2.0	*Cybersecurity Framework* 2.0 (NIST)	Kerangka keamanan siber dengan enam fungsi: *Govern*, *Identify*, *Protect*, *Detect*, *Respond*, dan *Recover*.
CSIRT	*Computer Security Incident Response Team*	Tim tanggap insiden siber. Kartika CSIRT adalah milik TNI AD.
CSP	*Content Security Policy* (kebijakan keamanan konten)	Aturan yang hanya mengizinkan skrip dan gaya milik aplikasi sendiri berjalan di layar.
CTI	*Cyber Threat Intelligence* (intelijen ancaman siber)	Kabar dari luar tentang ancaman yang sedang beredar, misalnya celah baru pada suatu perangkat.
Dansat	Komandan Satuan	Pimpinan unit; di sistem ini berperan sebagai Pengamat yang menerima laporan.
DDoS	*Distributed Denial of Service*	Serangan banjir permintaan agar layanan lumpuh karena kewalahan.
Deteksi anomali	Pengenalan perilaku tidak wajar	Menandai lalu lintas yang menyimpang dari kebiasaan, tanpa perlu daftar serangan yang sudah dikenal.
DMZ	Demilitarized Zone	Zona penyangga antara internet dan jaringan dalam, seperti lobi.
Drill Kesiapan	Latihan tanggap insiden bernilai	Fitur dasbor: log sintetis satu cerita, pertanyaan per fase penanganan, nilai 0–100 dari jejak yang tercatat sistem (Dokumentasi Teknis §3.5).
Enkripsi	Penyandian data	Mengubah data menjadi sandi. *Ransomware* memakainya untuk mengunci data korban.
Forensik digital	Penyelidikan bukti elektronik	Mengamankan dan memeriksa jejak digital agar pelaku bisa ditelusuri dan bukti sah.
HMAC	*Hash-based Message Authentication Code*	Segel digital berkunci. Setiap catatan log disegel dan terhubung ke catatan sebelumnya, sehingga perubahan diam-diam langsung ketahuan.
HSTS	HTTP Strict Transport Security	Aturan agar peramban selalu memakai sambungan terenkripsi.
HTTPS	Hypertext Transfer Protocol Secure	Sambungan web yang dienkripsi.

Istilah	Kepanjangan atau arti	Penjelasan sederhana
IIV	Infrastruktur Informasi Vital	Sistem elektronik yang gangguannya berdampak serius pada kepentingan umum; menurut Perpres 82/2022 termasuk sektor kesehatan dan pertahanan.
ISO/IEC 27037	International Organization for Standardization/International Electrotechnical Commission, standar 27037:2012	Pedoman internasional mengidentifikasi, mengumpulkan, mengambil, dan melestarikan bukti digital. Nusantara Shield mengikuti prinsipnya; belum diaudit terhadapnya.
Isolasi	Pemutusan jaringan	Memutus jalur perangkat yang diserang agar serangan tidak menyebar.
Isolation Forest	Nama algoritma *machine learning*	Cara mesin menemukan data yang aneh: data yang tidak wajar paling cepat "terpisah" dari kelompoknya.
IT	*Information Technology* (teknologi informasi)	Komputer kantor, *server*, dan jaringannya.
Kesdam	Kesehatan Daerah Militer	Badan pelaksana kesehatan di tingkat Kodam, membawahi rumah sakit jajaran.
Kesiapan Siber (nilai)	Rapor A–E kesiapan layanan dan posko	Gabungan dua sub-skor 0–100, Kerawanan dan Insiden; yang dipakai adalah yang lebih rendah.
Kodam	Komando Daerah Militer	Komando TNI AD tingkat wilayah (provinsi).
LAPSIT	Laporan Situasi	Laporan resmi singkat tentang insiden: apa, di mana, kapan, dan tindakan yang diambil.
LLM	*Large Language Model* (model bahasa besar)	AI penyusun teks, misalnya Llama 3 8B. Di proyek ini masih rencana.
Log audit	Catatan jejak	Daftar siapa melakukan apa dan kapan di dalam sistem.
Luring	Di luar jaringan (*offline*)	Berjalan tanpa sambungan internet.
Mabes	Markas Besar	Markas pusat, misalnya Mabes TNI atau Mabesad (Markas Besar TNI AD).
MISP	Malware Information Sharing Platform	Platform berbagi kabar ancaman antarlembaga.
ML	Machine Learning	Cara komputer belajar pola dari contoh data.
Modbus	Bahasa komunikasi mesin industri	Protokol untuk memerintah mesin seperti genset; memakai *port* 502.
MTTC	*Mean Time To Contain* (rata-rata waktu penahanan)	Rata-rata waktu dari insiden dimulai sampai ancaman ditahan, misalnya jaringan aset terdampak sudah diputus.
NIST	National Institute of Standards and Technology	Lembaga standar Amerika Serikat; SP 800-82 adalah panduan keamanan sistem industri, dan CSF 2.0 adalah kerangka keamanan siber umumnya.
OODA	*Observe–Orient–Decide–Act*	Siklus keputusan: Amati, Orientasi, Putuskan, Bertindak. Siapa yang lebih cepat, dia unggul.
Operator	Petugas jaga sistem	Satu-satunya peran yang boleh menekan tombol tindakan.
OSINT	Open Source Intelligence	Intelijen dari sumber terbuka, misalnya berita dan buletin keamanan.
OT	*Operational Technology* (teknologi operasional)	Perangkat yang mengendalikan mesin fisik, seperti genset dan catu daya rumah sakit.
PBKDF2	*Password-Based Key Derivation Function 2*	Cara menyimpan kata sandi dengan hitungan berulang, sehingga sulit ditebak bila berkasnya bocor.
PDNS	Pusat Data Nasional Sementara	Pusat data pemerintah yang lumpuh diserang *ransomware* pada Juni 2024.

Istilah	Kepanjangan atau arti	Penjelasan sederhana
Pemindaian *port*	*Port scan*	Satu alamat mencoba banyak "pintu" perangkat dalam waktu singkat untuk mencari layanan yang terbuka; sering menjadi tanda awal serangan.
Perketat	Pengerasan (*hardening*)	Tombol untuk mengurangi celah sebuah aset sebelum diserang.
Perpres	Peraturan Presiden	Perpres 82/2022 tentang Pelindungan Infrastruktur Informasi Vital mewajibkan simulasi tanggap insiden siber (Pasal 15).
Purwarupa	*Prototype*	Versi percobaan untuk membuktikan gagasan, belum dipakai di lapangan.
Pussiberad	Pusat Siber Angkatan Darat	Satuan pusat TNI AD yang menangani pertahanan siber; penyelenggara lomba.
RDP	Remote Desktop Protocol	Cara mengendalikan komputer dari jarak jauh.
RFC 5737	Standar alamat IP contoh	Blok alamat IP khusus dokumentasi yang tidak dipakai di internet sungguhan, sehingga aman untuk demo.
RSPAD	Rumah Sakit Pusat Angkatan Darat (Gatot Soebroto)	Rumah sakit rujukan tertinggi TNI AD di Jakarta.
Sansidam	Sandi dan Siber Kodam	Unit sandi dan siber di tingkat Kodam yang membantu satuan di wilayahnya.
Satuan	Unit organisasi militer	Misalnya rumah sakit TNI AD beserta personelnya.
SEV-1	*Severity 1* (tingkat keparahan tertinggi)	Label untuk insiden paling gawat.
SIMRS	Sistem Informasi Manajemen Rumah Sakit	Sistem komputer rekam medis dan layanan pasien.
SOAR	*Security Orchestration, Automation and Response*	Otomasi langkah respons keamanan, misalnya pemutusan jalur yang sudah disetujui.
SOC	*Security Operations Center* (pusat operasi keamanan)	Ruang dan tim yang memantau keamanan jaringan setiap saat.
SPK	Sistem pendukung keputusan	Sistem yang menyiapkan informasi dan pilihan tindakan; keputusan akhir tetap di tangan manusia.
SSE	*Server-Sent Events*	Cara *server* mengirim kabar terbaru ke layar secara langsung.
SSH	Secure Shell	Akses jarak jauh ke *server* lewat baris perintah.
STIX	Structured Threat Information Expression	Format standar untuk menulis kabar ancaman.
TAXII	Trusted Automated Exchange of Intelligence Information	Cara standar mengirim kabar ancaman antarsistem.
TNI AD	Tentara Nasional Indonesia Angkatan Darat	Matra darat dari angkatan bersenjata Indonesia.
Uji otomatis	*Automated test*	Daftar periksa yang dijalankan komputer untuk memastikan setiap aturan sistem benar.
WASPADA	Status siaga	Tanda kuning: aset berisiko tinggi diserang, walaupun serangan belum terjadi.
Zona kendali	Jaringan khusus mesin (OT)	Bagian jaringan tempat pengendali mesin fisik berada, dipisah dari jaringan kantor.